

# Frontdoors, Not Backdoors: Accountable Anonymity for National Digital Identity

Anonymous authors  
Anonymous affiliations  
Anonymous Emails

**Abstract**—Anonymous credentials (ACs) let users prove identity claims with strong privacy guarantees, and national systems inspired by them — EUDI and the Swiss e-ID — go live soon. Due to these privacy guarantees, however, the systems cannot detect *proof proxy attacks*, where malicious users present their credentials on behalf of other users, exposing a fundamental trade-off between privacy and accountability. For instance, users could sell anonymous legal age proofs online and get away with it. This lack of accountability may act as an obstacle for AC adoption on grounds of “national safety”, and issuing authorities may settle for less-than-ideal privacy guarantees of current solutions (e.g., batch issuance of one-show credentials).

In this paper, we advocate the need for integrated accountability in national digital identity. To this end, we introduce the *cryptographic forensic trail* (CFT). A CFT is a randomized encryption of a user’s identity attached to each credential show, and only upon probable cause for credential misuse can the CFT be decrypted for accountability. The multi-party design enforces separation of powers between law enforcement, a judicial body, and a digital privacy advocate (NGO). The protocol mimics checks and balances of a healthy democracy, in which no entity can track people as they will. Even if two branches colluded, the third one can detect the misuse and stop the process.

We implement a prototype of CFT based on both hardware-compatible and zero-knowledge-friendly elliptic curves. Our evaluations show that CFT adds only 13–16% computation overhead to credential shows on the user’s end, indicating that deployment in smartphone wallets is within reach.

## I. INTRODUCTION

Anonymous credential or AC systems, proposed more than 40 years ago by Chaum [1], provide maximal privacy for users when proving claims about themselves. A seminal AC design was provided by Camenisch and Lysyanskaya [2], which provided concrete desirable privacy properties: (i) *unlinkability* ensures that credential shows of users are not linkable; (ii) *unforgeability* ensures that users cannot manipulate attributes in credentials; (iii) *non-transferability* prevents a user from transferring (part of) their credential to another user, and; (iv) *anonymity revocation* revokes a user’s anonymity in case of misuse. These properties, if achieved simultaneously, make AC an ideal candidate for a privacy-preserving digital identity system.

Thus, ACs are now close to deployment: Switzerland and the EU plan to roll out digital-identity ecosystems in 2026–early 2027 [3], [4]. These national projects are AC-inspired, supporting selective disclosure and aiming for unlinkable presentations. However, the actual level of privacy still lags behind what would be expected from an ideal AC system. The Swiss e-ID will support selective disclosure and builds on single-use key pairs (batch issuance) [5]. While this provides unlinkability for verifier-verifier collusion, credential shows are linkable if issuers collude with verifiers. The European Data Protection Supervisor notes that AC technology could enhance privacy, although it has not yet been widely adopted [6]. Both initiatives therefore converge on the goal of secure, interoperable digital identities with selective disclosure, but do not provide maximal privacy yet [7]–[9]. Deployment of advanced cryptographic primitives, such as BBS signatures [10]–[12] or zero-knowledge proofs (ZKP), is discussed [8], [13]–[15], but currently blocked by a lack of support in secure enclaves on mobile phones and doubts about practicality [16]. We expect that standardizations and advances in ZKP research [13], [17], [18] will likely weather away these obstacles in a few years.

Yet, there is another obstacle to adopting stronger privacy with national digital identity projects: users could no longer be held accountable for misusing their credentials due to unlinkability. Specifically, a malicious user can execute a *proof proxy attack*, where they show their credential on behalf of another (illegitimate) user, and can go unpunished due to lack of accountability. For example, a malicious user could sell checks for legal age, which underage citizens could use to access gambling or erotic sites. The general availability of anonymous age checks at large scales would undermine age protection laws in general [19]. Unless addressed, these attacks provide a motivation to governmental authorities to settle with less privacy-preserving solutions planned for imminent roll-outs, which still allow tracking misuse if required. This is a bad trade-off, leaving the vast majority of honest users with weaker privacy. Yet deploying strong privacy alone invites a worse outcome: governments then undermine privacy more fundamentally through backdoors [20]—as seen in the EU’s and the EU nations’ push for chat-control [21]–[24], Switzerland driving away Proton [25], and the UK forcing Apple to withdraw end-to-end encrypted iCloud backups [26].

Hence, we argue that *if we want strong privacy to survive politically, accountability is a necessity*, and cryptographers should design it before politicians do. As mentioned above,

this is not an entirely new idea. Camenisch and Lysyanskaya proposed anonymity revocation for holding users accountable already 25 years ago, not as an afterthought, but as one of the important features [2]. Since then, however, accountability has received comparatively little attention in ACs: with some exceptions [27]–[29], the long line of further works [30]–[34] has primarily focused on performance, and stronger privacy. Alternative primitives, such as group signatures and their variants (see Table I), already provide accountability by letting a signature be opened; yet none of them is *standardization compliant*: none fits the technical stack that deployed e-ID systems have already fixed [35], [36]—credentials in the mDoc/mDL formats presented over OID4VP, and signing keys confined to mobile secure enclaves that today support only ECDSA. These are hard external constraints, and they rule out the accountability primitives proposed so far.

Hence, we present the *cryptographic forensic trail* (CFT), an accountability solution for ACs in a national identity framework, based on a democratic anonymity revocation committee. The CFT is a randomized encryption of the user’s identity that is attached to every credential show. It is used for revoking anonymity if users misuse their credentials, e.g. for proof proxy attacks (§II). Our design adopts a decentralized approach, unlike [2], which uses a central component. We strive towards the notion of *conditional anonymity revocation*, akin to *conditional anonymity* introduced in [37]: a user’s anonymity can be revoked *only if* the user is part of an investigation for a legitimate cause. Our goal is to emulate the legal process of “searching an individual” in the physical world. In particular, our design requires the law enforcement body (the police) to obtain a *digital search warrant* from the judicial body (the judge) before even initiating the anonymity revocation protocol. To make our approach more democratic, we further decentralize our system by including a *non-governmental organization* (NGO). The NGO ensures that the governmental bodies, the police and the judge, do not misuse the system for tracking benign users.

The main bottleneck of CFT is a zero-knowledge proof (ZKP) provided by the user on a smartphone. Using state-of-the-art ZKP libraries, we demonstrate its practical feasibility: CFT generation adds only 13–16% computation overhead to credential shows on the user’s device. Moreover, we discuss challenges regarding governance, committee composition, operation and legal questions around accountable AC systems, as well as possible future extensions in §VII.

The paper makes the following contributions:

- Thorough discussion of *proof proxy attacks* (§II) and advocating accountability as an integral part of AC-inspired e-ID systems for preventing proxy attacks.
- Design of the *cryptographic forensic trail* (CFT) for providing accountability in national e-ID systems (§IV).
- A prototype implementation (§V) and evaluation (§VI) for depicting the practicality of CFT deployment.

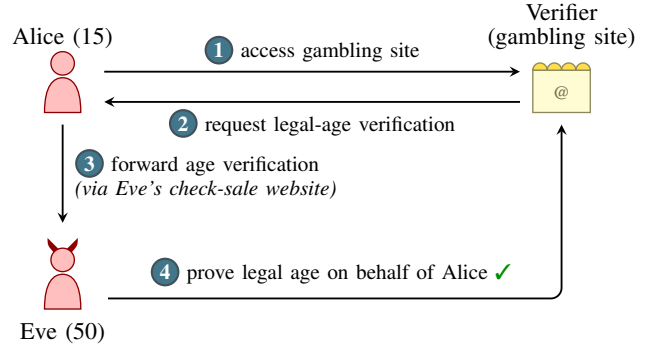


Fig. 1: Proof proxy attacks: Alice (age 15) bypasses the age check with Eve (age 50) proving legal age on her behalf.

## II. THE PROBLEM: PROOF PROXY ATTACKS

Before designing the CFT system, we discuss an important underlying problem – proof proxy attacks – and show why existing countermeasures fail to work in general scenarios.

In line with experts worldwide [8], [9], we believe that national electronic-ID (e-ID) systems should build on ACs with strong privacy, i.e., both verifier-verifier and issuer-verifier unlinkability. Assuming systems with strong privacy, we elicit an accountability problem: a user misusing her credentials by proxying proof presentations—and getting away with it [46]. For the specific use case of anonymous age verification, researchers have pointed out this potential misuse in an open letter addressed to politicians worldwide [19], calling for a moratorium on age verification legislation until harms are better understood [47] and technical aspects are clarified.

As illustrated in Figure 1, malicious users could sell anonymous checks on the internet (e.g. for legal age, nationality, personhood [48]) by having people forward the verifiers’ requests to them. While device binding of private keys effectively prevents transferability of identities, it does not prevent proof proxying. That is, Eve remains in exclusive possession of her private key (it is not transferred to Alice), but Eve leases (or lends) her identity temporarily for proving a statement on behalf of Alice. Such attacks are not mere or motivated reasoning: in the past, malicious users have abused anonymity, such as narcotics trafficking on Silk Road [49], [50], drug sale on AlphaBay [51], and cryptocurrencies for illegal transactions [52], [53]. In the e-ID context, such misuse includes illegal sale of age checks, citizenship, personhood, medical certificates, university degrees, etc. A more decoupled variant of this attack is possible, e.g., by users creating age-verified accounts on stock and selling them on the internet [54]. Legislation aims at protecting minors from adult content but also from adults joining age-restricted chats such as Roblox groups. With emerging markets and services around illegal age verification, such legislations would be rendered obsolete [19].

The Swiss and EU digital identity infrastructure, however, is envisioned to build the foundation for not just a single identity credential or a single use case like age verification, but an

| Scheme                                                 | Strong<br>Unlinkability | Standard.<br>compliant | Anonymity Revocation with privacy |                     |                  |                            |
|--------------------------------------------------------|-------------------------|------------------------|-----------------------------------|---------------------|------------------|----------------------------|
|                                                        |                         |                        | Multi-party<br>opening            | Revoke<br>signature | Trace<br>user ID | Trace user<br>ID with thr. |
| National e-ID (Swiss e-ID, EUDI)                       |                         |                        |                                   |                     |                  |                            |
| Batch issuance-based (current) [35], [36] <sup>†</sup> | ✗                       | ✓                      | ✗                                 | NA                  | NA               | NA                         |
| ZKP-based (future) [38]                                | ✓                       | ✓                      | ✗                                 | ✗                   | ✗                | ✗                          |
| Existing cryptographic primitives                      |                         |                        |                                   |                     |                  |                            |
| Anonymous Credentials [2], [28]                        | ✓                       | ✗                      | ✗                                 | ✓                   | ✗                | ✗                          |
| Group Signatures [10], [11], [39] <sup>‡</sup>         | ✓                       | ✗                      | ✗                                 | ✓                   | ✗                | ✗                          |
| Threshold Group Signatures [40]                        | ✓                       | ✗                      | ✓                                 | ✓                   | ✓                | ✗                          |
| Traceable Signatures [41]–[43]                         | ✓                       | ✗                      | ✗                                 | ✓                   | ✓                | ✗                          |
| Hidden ID-Based Signatures [44]                        | ✓                       | ✗                      | ✗                                 | ✓                   | ✓                | ✗                          |
| Identity Escrow [37], [45]                             | ✓                       | ✗                      | ✓                                 | ✓                   | ✗                | ✗                          |
| Cryptographic Forensic Trail (This Work)               | ✓                       | ✓                      | ✓                                 | ✓                   | ✓                | ✓                          |

TABLE I: Comparison of e-ID and cryptographic schemes. ✓ = supported, ✗ = not supported, NA = not applicable (see <sup>†</sup>). *Anonymity Revocation with privacy* groups different ways to revoke anonymity: involving multiple parties in the opening, revoking a single signature, tracing signatures of a given user ID, and tracing only user IDs surpassing a threshold. <sup>†</sup>: batch issuance fails to provide unlinkability when issuers and verifiers collude and without unlinkability revocation is not necessary; <sup>‡</sup>: the scheme of [10] introduced the pairing-based construction later adapted into BBS+ [11] and modern BBS [12].

entire *ecosystem around digital credentials* [35], [55]. Issuers from various government offices and industry are invited to issue their own domain-specific credentials. Standards for health, financial, and education sectors are currently being developed. Some of these credentials may not require hardware device binding, which simplifies key extraction and misuse even more. If not protected carefully, the next generation of agentic AI systems [56] could obtain credentials proving personhood [48], legal age, citizenship, etc. Markets for resold age-verified accounts [54] already demonstrate that the business model is commercially viable at small scale.

A straightforward solution for preventing such attacks is by including the verification of holder binding into the design. This is usually done by visually matching a picture stored on the credential with the presenting person [57]. Such an approach seems suitable for EUDI and Swiss e-ID as they include a biometric feature (face) and are device bound, i.e., keys are stored in the secure enclave of the user’s smartphone. So whenever the owner presents the e-ID to a human verifier, e.g., when buying a beer in a bar, the verifier can verify holder binding by doing in-person biometric authentication. However, *many online use cases will neglect the verification of holder binding*. This is because while image- and video-based identification solutions could do the job in theory, they are costly and require biometric data to be processed, which raises data protection issues. Also, users may hesitate to upload their pictures to websites requiring legal age verification. Moreover, cameras might not be available on all devices (e.g., self-checkout systems in shops or restricted office clients).

The Federal Office of Information Technology (FOITT) of Switzerland, which operates the Swiss e-ID, acknowledges

the threat of proof proxy attacks [58] (chapter 6.9), rating its impact as **HIGH** and its likelihood as **LOW**. An option discussed for mitigation is by “tracking down the credential in question and revoke it”, indicating the lack of unlinkability during credential shows. In fact, with the current system using batch issuance [5], FEDPOL, the federal police and issuer of the Swiss e-ID, would be able to track down credentials by collaborating with verifiers. Such a design choice is problematic since it makes all users vulnerable to getting tracked, even if there is no legitimate cause. However, if FEDPOL eventually adopts a more privacy-preserving system, e.g., using ZKPs [13], [59], the ability to “track down” malicious actors would vanish.

Alternatively, the FIDO CTAP hybrid flow, proposed for the EUDI wallet [35], tunnels the verifier’s browser session and the wallet over Bluetooth Low Energy (BLE), requiring the proving device to be physically nearby and thus raising the bar against remote QR-code forwarding. It does not prevent proof proxying, however: a user can still share her browser session or open a BLE tunnel to a colluding prover; it protects only synchronous presentations, offering no defense against age-verified accounts resold in bulk [54]; and it inherits BLE’s known security and privacy weaknesses [60].

### III. OVERVIEW

This section describes the high-level workflow and scenarios for the cryptographic forensic trail (CFT) usage (§III-A and §III-B), the anonymity revocation committee (§III-C), the system model (§III-D), and the threat model (§III-E). Broadly speaking, a CFT is an encrypted identifier attached to every credential show, and only if the credential holder is involved in

any unlawful activities, such as proof proxy attacks, this trail is decrypted to revoke the holder’s anonymity. The motivation for introducing the forensic trail<sup>1</sup> parallels that of anonymity revocation in idemix [2], [30], serving as a mechanism for enabling accountability in ACs.

#### A. Workflow

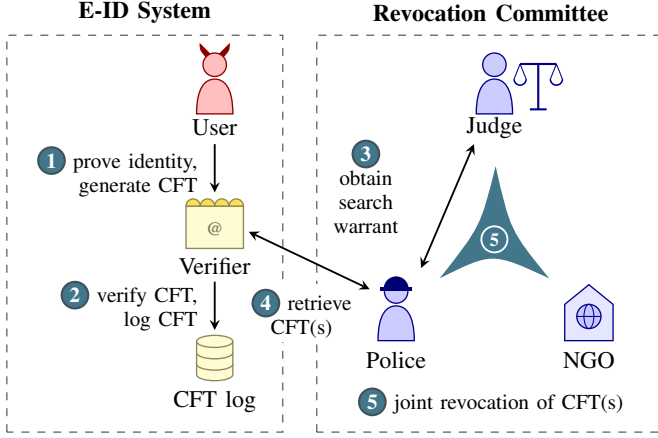


Fig. 2: Cryptographic forensic trail (CFT) workflow: user generates the CFT while showing her credential to the verifier ①, who verifies and logs the CFTs ②; after obtaining a digital search warrant ③, the police retrieve the relevant CFT record(s) ④. Finally, the revocation committee runs a protocol together to revoke the anonymity of the CFT(s) ⑤.

Figure 2 depicts the high-level workflow of the use of CFT for ensuring accountability in the e-ID system, where the law enforcement body (the police), the judicial body (the judge), and an NGO to work together for anonymity revocation. This design decentralizes the accountability framework and makes it impossible for a single entity to revoke the anonymity of any user as they will (see §III-C for more details).

In the following, we discuss the scenarios w.r.t. the proof proxy attack (§II). Note that *nothing* related to the buyer’s identity (Alice in Figure 1) is stored in a CFT; we only aim to hold (malicious) users that sell their identities accountable (Eve). The search warrants in ③ are a prerequisite for any criminal investigation under Swiss law [61, Arts. 269–279] and the EU Law Enforcement Directive [62].

#### B. Scenarios for Anonymity Revocation

The number of relevant CFT(s) ④ and the exact semantics of the revocation protocol ⑤ depend on the amount of information available for investigation, which lead to three scenarios of anonymity revocation.

- 1) *Search by request ID*. The police know the specific CFT whose anonymity should be revoked to find the person behind the anonymous check sale service (Eve). This may be the case when a public service selling age checks

is accessible and police perform a sting operation-like procedure [63] by buying an age proof themselves (§IV-E).

- 2) *Search by suspect ID*. In this scenario, the police have the ID of the suspect but do not know which requests belong to the suspect. This scenario becomes relevant when a whistleblower (or any other source) informs the police about Eve being potentially involved in suspicious activities or because the police learned Eve’s ID from *Search by request ID* (§IV-F).
- 3) *Search by activity threshold*. In this scenario, the police only have knowledge about someone (not the ID) executing a proof proxy attack. For instance, the police solely learn many underage citizens are accessing gambling sites and nothing about Eve. Thus, the police will try to find the ID of a person that appears abnormally often (§IV-G).

These protocols are useful beyond investigating proof proxy attacks. For instance, during a court-authorized investigation into organized fraud, matching e-ID activity to a known suspect can provide material evidence. This is a feature, not a bug: a national digital identity system cannot stand above the law, granting its users exceptional immunity that does not exist for users of other digital or physical systems.

#### C. The Decentralized Revocation Committee

Idemix [30] assumes the existence of a *centralized revocation authority*, and presents anonymity revocation as an optional feature in ACs. In contrast, we hold that there must be a *decentralized* unit, which we refer to as the *revocation committee*, for anonymity revocation, and this committee must contain multiple independent entities. Furthermore, anonymity revocation should not be optional; it should be applicable to all users, but only triggered in cases of legal non-compliance. That is, anonymity revocation should be *conditional*, not optional.

But which parties should be involved in anonymity revocation? In this regard, an e-ID system should not re-invent new legal processes; it should emulate the legal structure that has existed for centuries in healthy democracies. Specifically, in democracy, citizens have privacy rights until they violate some law. Even when the law enforcement body (the police) finds an indication for law violation (probable cause), it cannot simply override the right to privacy. The police must convince the judicial authority (the judge) of a violation and get a signed search warrant before overriding the privacy of any citizen. This structure has been functioning in democracies for a long time [64], [65]. Hence, we hold that e-ID systems must emulate this process for accountability: the police should be able to search the credential shows of an individual only if the judge issues a (digital) search warrant against that individual.

A concern with only the police and the judge forming the committee in the digital world is the possibility of covert tracking: by colluding with each other, they can track all the credential users, and it is much easier to track digitally than tracking people physically. Hence, the anonymity revocation committee must contain one or more organizations which are independent of government bodies, such as NGOs or interna-

<sup>1</sup>We use “forensic trail”, “trail”, and “cryptographic forensic trail” interchangeably.



tional bodies (we use “NGOs” to refer to such organizations), who can act as deterrents to governments going rogue.

a) *NGOs for the revocation committee*: Genuine independence from the state is the key criterion for selecting NGOs, since most civil society organizations receive at least some public funding. A pragmatic way to identify suitable candidates is to favor organizations that are member- or donor-supported, with a track record of publicly opposing surveillance legislation backed by their own governments. Candidates meeting this bar include noyb [66] and EDRi [67], which have repeatedly co-signed open letters against the EU CSA Regulation [68]; the membership-funded EFF [69]; AlgorithmWatch [70] and Digitale Gesellschaft [71] in Switzerland; and the digital-rights and scientific communities behind recent open letters on age assurance and the EUDI framework [19], [47]. Technical expertise, where needed, could come from organizations such as the Chaos Computer Club [72] or the Tor Project [73]. Combining several such organizations across jurisdictions further reduces the risk that any single government can coerce the non-governmental party.

#### D. System Model

Our system, as outlined in Figure 2, consists of the revocation committee and the three core entities of the national ID system (EUDI, Swiss e-ID, etc.): (i) the issuer who issues credentials (not shown in Fig. 2); (ii) the user who obtains a credential from the issuer, and; (iii) the verifier who verifies the credential before providing some service. The credentials contain attributes of the user, and one of the attributes is a technical identifier (e.g., Social Security Number). The user owns a public key-secret key pair, which is required for generating signatures of knowledge. We assume that secret keys are bound to a Wallet Secure Cryptographic Device (WSCD) — either a local secure enclave on the user’s phone or a remote HSM with per-user partitioning — as specified by the EUDI ARF [35] and the Swiss e-ID [36]. In both cases, keys are non-extractable, and an attacker can only generate CFTs that point to her own identity. Resale therefore reduces to selling access to one’s own wallet (locally) or one’s own remote-signing account (remotely); in both cases CFT correctly identifies the seller.

In our system, the verifier needs to store the credential shows of (anonymous) users for a certain duration (e.g., six months or a year) 2. This is in line with many national data retention policies requiring phone and internet service providers to store metadata for some duration [74]–[78].

The anonymity revocation committee members also hold individual public key-secret key pairs. In a CFT deployment, each member organization maintains a computation node running the distributed revocation 5 with the computation nodes of the other members. Each computation node must have access to its owner’s secret key. These secret keys must be stored securely, analogous to how certificate authorities protect their private keys, e.g. in a local HSM. Since many individuals (e.g., investigators and judges) interact with each organization’s node, we assume organizations enforce role-

based access control: only investigators may request a warrant, only appointed judges may issue one, and only authorized NGO representatives may object to a revocation. A node then starts the actual revocation protocol only once all members have completed their preliminary tasks and given their consent.

#### E. Threat Model

Our system aims to defend against a user who attempts to abuse the privacy guarantees of the e-ID by selling her anonymous credential shows. We assume that the issuer issues credentials correctly, i.e., the issuer signs the right set of claims and does not issue duplicate credentials to users.

We assume the identity system is built on anonymous credentials, so credential shows remain unlinkable even under cross-verifier and issuer-verifier collusion. Verifiers are expected to check proofs and log credential shows; to deter deviations, verifier logs can be audited at random, akin to cut-and-choose technique [79]. Furthermore, certification of verifiers and a trust registry - as envisioned by EUDI and Swiss e-ID - could guide users towards responsible verifiers and build incentives for verifiers to comply.

We assume that the wallet application held by users is untrusted. A “trusted wallet” assumption could be enforced via platform attestation (e.g., Google Play Integrity [80], Apple App Attest [81]), which certifies that the wallet app is authentic and runs on a secure device. The required long-term mTLS key, however, would itself act as a linkable identifier across presentations, breaking unlinkability.

We assume an *honest-but-curious* setting, and we assume that 1-out-of-3 parties among the law enforcement body (the police), the judicial body (the judge), and the non-governmental body (the NGO) is honest, and the protocol 5 is aborted in case an honest party detects tracking attempts or deviation from the protocol by any party. For example, in an authoritarian country, the judge and the police might work together, or a corrupted NGO might collude with the police. In such cases, the honest party could stop the entire process. If collusion of more than two parties is feared, the revocation committee can be more decentralized (e.g., involving more NGOs); although involving more parties would lead to more computation / communication costs. Such adaptations can be easily made to our main protocol, and hence, we describe our solution based on the 1-out-of-3 assumption in §IV.

#### F. Isn’t this a Backdoor?

The cryptographic community has documented the risks of exceptional-access mechanisms, so-called backdoors, in detail [82], [83], including unilateral control, catastrophic failure modes [84], and lawful-access infrastructure being compromised by unintended parties (e.g., Salt Typhoon) [85]. Backdoors are typically associated with several distinct properties listed in Table II, which rightly trigger a defensive reaction among security researchers [22].

However, the CFT is categorically different from a backdoor, exhibiting none of the backdoor properties (see Table II). While backdoors correspond to “keys under doormats” [82],

| Property                           | Backdoor                                                                                            | Cryptographic Forensic Trail                                             |
|------------------------------------|-----------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| Power to act                       | One actor, unilaterally                                                                             | Committee consisting of police, judge, and NGO                           |
| Scope of use                       | Potential for massive scaling: one key, many targets                                                | Clearly defined scope in each warrant                                    |
| Precondition                       | Technical capability or knowledge is the only gate; it can be leaked, stolen, or sold               | Probable cause, judicial warrant, and NGO consent                        |
| Weaker security                    | Security of the system is deliberately weakened, e.g., patches retained or weak parameters selected | The core identity system is untouched; accountability is an add-on layer |
| Data confidentiality and integrity | Confidentiality, integrity, and availability properties of all user data are at risk                | All transaction data remains secure; only metadata is de-anonymized      |
| Security by obscurity              | APIs are hidden from the public                                                                     | Public governance                                                        |
| Abuse detection                    | No; use is invisible                                                                                | Yes; the NGO can detect and halt systemic misuse                         |
| Capability revocable               | No; once deployed, it persists                                                                      | Yes; oppression-resilience through key destruction                       |

TABLE II: What makes CFT categorically different from a backdoor.

the CFT is rather a frontdoor with multiple locks and no accessible keys. With the CFT, we are not trusting the state more to handle exceptional access. We are trusting no single party at all, including the police, the judiciary, and the NGO. This is the same logic by which democratic societies accept that police exist, without concluding that police can enter any home at any time. The answer to “police have too much power” has never been “abolish investigation”. It has been separation of powers, checks and balances, probable cause, warrants, and oversight. The CFT is the cryptographic instantiation of that same answer.

Note that ACs without accountability mechanism are not analogous to a private home as we know it. Rather, it is analogous to *diplomatic immunity*, an exemption from law that society only grants in narrow, reciprocal cases. Extending this immunity-level of privacy to every credential show for every user and every transaction is a political proposition that will not survive contact with democratic legislatures. If accountability is not designed into systems, politicians will likely enforce it by weakening the systems — by building *actual* backdoors. Recent example for this are the recurring discussion about chat control in the EU (see Appendix A) but also Switzerland’s new proposed surveillance laws that let Proton threaten to leave the country [25].

#### IV. CRYPTOGRAPHIC FORENSIC TRAIL

In this section, we detail the core design of the cryptographic forensic trail (CFT). The main challenges when designing CFT are that first, the user is not trusted. Second, we want to maintain the strong level of unlinkability, resilient against collusion of issuers and verifiers. Thus, the CFT must not introduce data items that give away unlinkability. We hold up unlinkability even for those transactions of malicious users that are not direct subject of investigation. Third, the entities holding users accountable must themselves be held accountable in order to prevent unlawful anonymity revocation.

Figure 2 presents a high-level overview of our solution. We first describe how the CFT is created during credential show (§IV-B) ①, and then, we discuss how the anonymity of a user can be revoked using the CFT (§IV-D) ⑤.

TABLE III: Notations

| Notation  | Description                                                                          |
|-----------|--------------------------------------------------------------------------------------|
| $I, U, V$ | Issuer, User, Verifier                                                               |
| $P, J$    | Police, Judge                                                                        |
| $N$       | Non-governmental organization (NGO)                                                  |
| $cred_U$  | Credential issued by the issuer to the user                                          |
| $atirs$   | Attributes of the user                                                               |
| $atirsv$  | Attributes that the user needs to show to the verifier                               |
| $CFT$     | Cryptographic forensic trail                                                         |
| $t$       | Event-binding tag derived from the public request transcript: $t = H(ts, RID, ID_V)$ |

##### A. Notations

Table III summarizes the notations used. We write group operations additively in a cyclic group  $\langle G \rangle$  of prime order  $q$  (e.g., an elliptic-curve group) with generator  $G$ . Public keys, including the user’s accountability public key  $ID_U$  (equivalently  $pk_U$ ), are elements of  $\langle G \rangle$ , while secret keys and randomness  $(r_1, r_2)$  are scalars in  $\mathbb{Z}_q$ . Each party  $i \in \{U, V, P, J, N\}$  holds a key pair  $(PK_i, sk_i)$  with  $PK_i \in \langle G \rangle$  and  $sk_i \in \mathbb{Z}_q$ . The user holds a key pair  $(pk_U, sk_U)$  with  $pk_U = sk_U \cdot G$ ;  $ID_U$  denotes  $pk_U$  and is the value encrypted in  $C_3$ . The secret key  $sk_U$  is hardware-bound (non-extractable), so that the binding signature  $C_4$  also provides device binding. A presentation request is identified by the tuple  $(ts, RID, ID_V)$ —a timestamp, the request identifier (RID), and the verifier’s identifier ( $ID_V$ )—treated as public values.

##### B. Cryptographic Forensic Trail Generation

Figure 3 depicts the steps involved in the generation of the cryptographic forensic trail (CFT) ①. On a high level, a cryptographic forensic trail (CFT) is a randomized encryption of the user’s accountability public key (identifier)  $ID_U$  under a joint public key of the police, the judge, and the NGO. We instantiate the CFT using an ElGamal-style construction due to three main reasons: (i) since ElGamal is additively homomorphic in the public key, the user can encrypt in one step under  $PK_{CFT} = PK_P + PK_J + PK_N$  (rather than

nested encryption), keeping the corresponding proof of correct encryption compact; (ii) ElGamal naturally lives on elliptic-curve groups, which enables zk-friendly curve choices [86], [87] and can make the proof of correct encryption cheaper than RSA-based approaches, and; (iii) ElGamal-style operations commute with Pohlig-Hellman-style [88] blinding used in our two-phase conditional opening approach (§IV-F), which lets the parties transform a probabilistic, unlinkable trail into a deterministic blinded identifier PID within the warrant scope without decrypting benign users.

a) *CFT Content*: The CFT is formed from four elements:

- $C_1 = r_1G$ : a first ElGamal ephemeral public key.
- $C_2 = r_2G$ : a second ElGamal ephemeral public key, used to derive the binding message at opening time.
- $C_3 = ID_U + r_1PK_{CFT}$ : the ElGamal ciphertext component that encrypts the user's public key  $ID_U$  under the joint public key  $PK_{CFT}$ .
- $C_4 = \text{Sign}_{sk_U}(H(t, r_2PK_{CFT}))$ : a signature under the user's hardware-held secret key  $sk_U$  on the binding message  $H(t, r_2PK_{CFT})$ , where the event tag is  $t \leftarrow H(ts, RID, ID_V)$ . Because  $sk_U$  never leaves the secure enclave,  $C_4$  simultaneously binds the CFT to the request transcript and provides device binding: only the device that holds  $sk_U$  can produce a valid  $C_4$ . After opening, the revocation committee verifies  $\text{VerifySign}_{ID_U}(C_4, H(t, r_2PK_{CFT}))$  using the recovered public key  $ID_U$  and  $r_2PK_{CFT}$  obtained from  $C_2$  (Theorem 2). Because the binding message depends on  $r_2PK_{CFT}$ , which is hidden in  $C_2$  until threshold partial decryption, an adversary cannot verify candidate signatures offline: without knowing  $H(t, r_2PK_{CFT})$ , brute-force attempts against  $C_4$  are futile even if  $t$  is public.

b) *CFT Proof*: During the credential show, the user proves in zero-knowledge (to the verifier) that the CFT is well-formed and correctly bound to the public request transcript; we instantiate this proof as a zk-SNARK [89]. The full circuit description of the proof can be found in our anonymous implementation repository<sup>2</sup>. The predicate  $\text{VerifyCFT}()$  asserts that  $C_1 = r_1G$ ,  $C_2 = r_2G$ ,  $C_3 = ID_U + r_1PK_{CFT}$ , and  $\text{VerifySign}_{ID_U}(C_4, H(t, r_2PK_{CFT})) = 1$  for the user's identifier  $ID_U = pk_U$ .

c) *CFT Verification*: The user sends the CFT and the proof to the verifier, who must perform the following tasks ②: (i) verify the zero-knowledge proof  $\pi_U$  and if the proof fails, it must abort the transaction; (ii) store the CFT along with the ID of the presentation request and a timestamp. In order to prevent verifiers from deviating from the two tasks, we require them to store the proofs and the required randomness for a certain duration, like six months to a year. These proofs do not leak anything about the provers and can be checked at random, akin to the cut-and-choose technique [79].

<sup>2</sup>[https://anonymous.4open.science/r/accountability\\_for\\_acs-7670/prove-verify/zk-friendly/prove-verify/prove\\_verify.circom](https://anonymous.4open.science/r/accountability_for_acs-7670/prove-verify/zk-friendly/prove-verify/prove_verify.circom)

### C. Security of the CFT

We briefly argue event binding and the privacy/security properties of the trail. Formal games and reductions appear in Appendix E. We assume DDH in  $\langle G \rangle$ , model  $H$  as a random oracle, the signature scheme used for  $C_4$  as EUF-CMA, and the presentation proof system to be sound and zero-knowledge.

a) *Event binding*.: Each show derives  $t = H(ts, RID, ID_V)$  from the public request and forms  $C_4 = \text{Sign}_{sk_U}(H(t, r_2PK_{CFT}))$  under the hardware-held  $sk_U$ . At presentation,  $t$  is a public input of  $\pi_U$ , so accepting the proof binds  $(C_1, \dots, C_4)$  to *this* verifier, request, and time: replaying the same  $(CFT, \pi_U)$  under another  $t$  fails verification, and soundness prevents adapting a valid show for one event into a valid show for another without the credential witness. At opening, the committee recomputes  $t$  from the logged metadata, derives  $r_2PK_{CFT}$  from  $C_2$ , recovers  $ID_U$ , and checks  $C_4$ ; a trail swapped onto a different logged event fails that check. Producing a trail for a fresh event is covered by unforgeability below.

b) *Indistinguishability and unlinkability*.: Semantic security is cast as an IND-style game: the adversary picks two candidate identities, receives a challenge trail encrypting one of them, and may sample further honest trails for the same hidden identity.

**Theorem 1** (Trail indistinguishability). *Under DDH in  $\langle G \rangle$  and modelling  $H$  as a random oracle, no PPT adversary wins the IND game with non-negligible advantage.*

*Intuition*. The reduction places a DDH challenge in  $(C_1, C_3)$ ; in the real case the transcript matches an honest trail, while in the random case  $C_3$  is uniform and hides  $ID_U$ . Even knowing both candidate signing keys, verifying  $C_4$  offline still requires  $r_2PK_{CFT}$ , which is CDH-hard from public  $(C_2, PK_{CFT})$ . Fresh randomness then makes successive trails for the same user indistinguishable from trails of different users, and zero knowledge of  $\pi_U$  adds no linking information beyond the public inputs. Without all three committee keys, deciding cross-show identity equality is hard.

c) *Unforgeability*.: Anyone can form ElGamal components  $(C_1, C_2, C_3)$  for a known  $ID_U$ , the binding signature  $C_4$  is the hard part.

**Theorem 2** (Trail unforgeability). *Assuming EUF-CMA of the signature scheme used for  $C_4$ , and assuming the adversary does not know  $sk_U$ , no PPT adversary can produce a valid trail for a fresh tag except with negligible probability.*

*Intuition*. A forgery for a new tag  $t'$  needs a valid signature on  $H(t', r'_2PK_{CFT})$  under  $ID_U$ . Without the hardware-held  $sk_U$ , that reduces to EUF-CMA, even given many honest trails for other events.

Next, we discuss the steps involved in anonymity revocation using CFT in each of the three scenarios discussed in §III-A.

### D. Anonymity Revocation using CFT

The anonymity revocation is run using three main subroutines: (i) search warrant issuance ③; (ii) obtaining relevant

**Algorithm 1: CFTCreate**

**Parties:** User  $U$ , Verifier  $V$   
**Inputs:** user's key pair  $(pk_U, sk_U)$  with  $ID_U \leftarrow pk_U$ , verifier's identifier  $ID_V$ , shown attributes  $atrs_V$ , timestamp  $ts$ , request ID  $RID$ , public keys  $\{PK_P, PK_J, PK_N\}$ , predicate  $f_V(\cdot)$

- 1:  $U$  derives an *event-binding* tag from the public request transcript:  

$$t \leftarrow H(ts, RID, ID_V) \quad (1)$$
- 2:  $U$  generates the cryptographic forensic trail  $CFT$  as an ElGamal-style ciphertext with a signature binding component (where  $PK_{CFT} \leftarrow PK_P + PK_J + PK_N$ ):  

$$\begin{aligned} \text{sample } r_1, r_2 &\xleftarrow{\$} \mathbb{Z}_q, \\ m &\leftarrow H(t, r_2 PK_{CFT}), \\ C_1 &\leftarrow r_1 G, & C_2 &\leftarrow r_2 G, \\ C_3 &\leftarrow ID_U + r_1 PK_{CFT}, & C_4 &\leftarrow \text{Sign}_{sk_U}(m), \\ CFT &\leftarrow (C_1, C_2, C_3, C_4) \end{aligned} \quad (2)$$
- 3:  $U$  generates the zero-knowledge proof,  $\pi_U$ :  

$$\pi_U = \text{SNARK} \left[ \begin{aligned} &(atrs, ID_U, CFT, r_1, r_2, t, PK_{CFT}) : \\ &\text{VerifyCred}(atrs) = 1 \\ &\wedge f_V(atrs_V) = 1 \\ &\wedge \text{VerifyCFT}(PK_{CFT}, CFT, ID_U, t) = 1 \end{aligned} \right] \quad (3)$$
- 4:  $U$  sends  $CFT$  and  $\pi_U$  to  $V$ .
- 5:  $V$  verifies the correctness of  $\pi_U$ :  

$$V_{\pi_U} = \text{VerifySNARK}(vk_{\text{SNARK}}, \pi_U, PK_{CFT}, CFT, atrs_V, t) \quad (4)$$
- 6: **if**  $V_{\pi_U} = 1$  **then**
- 7: |  $V$  stores  $CFT$  and  $\pi_U$
- 8: **else**
- 9: | **Abort**

Fig. 3: Generation of CFT and Zero-Knowledge Proof

trails (4) and; (iii) partial decryption of relevant trails (5). These subroutines are needed for all three scenarios of §III-A, but their exact inputs, outputs, and semantics vary. We provide concrete instantiations of the three subroutines in Figure 4 (on the right) with respect to the search by request ID scenario, which we discuss below:

- **IssueWarrant:** in this subroutine, the police justifies the need for a search warrant to the judge. After verifying the legitimacy of the case, the judge issues a search warrant, which is a digital signature that ties the search warrant to a search ID, the reason for warrant issuance (**reason**), and some auxiliary information (**aux**). The auxiliary information specifies information relevant to the search such as the procedure of search, the number of CFTs whose anonymity should be revoked, or the verifiers that should be contacted.
  - **ObtainTrails:** the police runs this subroutine with the relevant verifier(s) to obtain the CFT(s) whose anonymity needs to be revoked. In the "search by request ID" scenario, the police get exactly one CFT.
  - **PartialDecrypt:** this subroutine is run by a revocation committee member for removing a layer of encryption of CFT.
- Next, we detail the whole search procedure for the search

by request ID scenario using the subroutines.

**E. Searching by Request ID**

The procedure for search by request ID has been depicted in Figure 4 (left). Before any of these subroutines are called, the police first acquires the reason for search warrant issuance, which is the proof proxy attack in our case, from sources such as investigative journalism, web crawling for suspicious online activities, or voluntary whistleblowing. Thereafter, the police runs the **IssueWarrant** subroutine with the judge. **IssueWarrant** outputs the search warrant to proceed with the search.

If the police does not have the request ID (RID) yet, it uses a sting operation-like approach [63] to acquire the relevant trail by approaching the malicious user as a buyer of an anonymous online check for the verifier's service. Specifically, the police works together with a specific verifier (mentioned in the **aux**) to run the **ObtainTrail** subroutine. Then, the police uses the request ID (RID) to pinpoint the relevant CFT that the malicious user bought. After obtaining the CFT, the police, the judge, and the NGO invoke the **PartialDecrypt** on the CFT to obtain the user's public key ( $ID_U$ ). The partial decryption of the CFT can be done in any order but the last **PartialDecrypt** should perhaps be invoked by the police since the police would continue further investigation. Furthermore, the entire search procedure includes multiple checkpoints, such as parties verifying signatures and the search reason. These checkpoints imply that the search procedure aborts if the party cheats or if the police tries to revoke the anonymity of a benign user. One could attempt to enforce these checkpoints cryptographically, but doing so does not provide the system with stronger security guarantees (see ?? VII-0e).

**F. Searching by Suspect ID**

We present the complete procedure for Search by Suspect ID in Figure 8 (see appendix). The subroutine **IssueCondWarrant** is pretty much the same as **IssueWarrant**, except the police needs to provide more justification for searching multiple records. The **ObtainTrails** needs minor modifications w.r.t. **ObtainTrail** since the police cannot use a sting operation-like approach as the RID is unknown; instead the police obtains relevant trails from relevant verifier(s).

**PartialDecrypt** subroutine, however, needs major changes: if this subroutine is used without any modifications, then the police can see in clear when and how many times a user ID appears. With this leakage, if the police can collude with an issuer, then the police learns the identity of people using a service and their usage patterns. Hence, we propose a paradigm similar to that of Segal et al. [90], which we refer to as *two-phase partial decryption (link-then-decrypt* in our evaluation, §VI): the key idea is to map each trail to a blinded identifier PID and then, compare each blinded identifier with the input suspect ID. Our instantiation uses the Pohl-Hellman trick to convert the randomized ElGamal encrypted CFT to a deterministic blinded identifier PID. Since each PID is generated using a fresh randomness, the blinded identifiers of benign users remain unlinkable as long as one of the members



**Algorithm 2: CFTRevokeByRequestID**

**Parties:** Police  $P$ , Judge  $J$ , NGO  $N$ , Verifier  $V$   
**Inputs:**  $\text{reason}$ ,  $\text{aux}$ ,  $ID_{SW}$ ,  $RID$  (possibly NULL), public keys  $pk_i$  for  $i \in \{P, J, N\}$ ; each party  $i$  holds its own secret key  $sk_i$

- 1:  $P$  finds a cause for search warrant issuance.
- 2:  $\sigma_{SW} \leftarrow \text{IssueWarrant}(P, J, \text{reason}, \text{aux}, ID_{SW})$
- 3:  $(CFT, ts, RID, ID_V, \sigma_{SW,V}) \leftarrow \text{ObtainTrail}(P, V, \sigma_{SW}, RID)$ , where  $CFT = (C_1, C_2, C_3, C_4)$
- 4:  $P$  sends  $CFT, (ts, RID, ID_V), \sigma_{SW}, \sigma_{SW,V}$  to  $N$ .
- 5: **if**  $\text{reason}$  not legitimate  $\vee \sigma_{SW}$  is invalid  $\vee \sigma_{SW,V}$  is invalid **then**
- 6:  $\perp$   $N$  aborts.
- 7:  $(D_{(1,N)}, D_{(2,N)}) \leftarrow \text{PartialDecrypt}(N, C_1, C_2, sk_N)$
- 8:  $N$  forwards  $(D_{(1,N)}, D_{(2,N)})$  to  $P$ .
- 9:  $P$  sends  $CFT, (ts, RID, ID_V), \sigma_{SW}, \sigma_{SW,V}$  to  $J$ .
- 10: **if**  $\sigma_{SW}$  is invalid  $\vee \sigma_{SW,V}$  is invalid **then**
- 11:  $\perp$   $J$  aborts.
- 12:  $(D_{(1,J)}, D_{(2,J)}) \leftarrow \text{PartialDecrypt}(J, C_1, C_2, sk_J)$
- 13:  $J$  forwards  $(D_{(1,J)}, D_{(2,J)})$  to  $P$ .
- 14:  $(D_{(1,P)}, D_{(2,P)}) \leftarrow \text{PartialDecrypt}(P, C_1, C_2, sk_P)$
- 15:  $P$  combines partials and checks the binding:  
 $ID_U \leftarrow C_3 - (D_{(1,P)} + D_{(1,N)} + D_{(1,J)})$   
 $D_2 \leftarrow D_{(2,P)} + D_{(2,N)} + D_{(2,J)}$   
 $t \leftarrow H(ts, RID, ID_V)$
- 16: **if**  $\text{VerifySign}_{ID_U}(C_4, H(t, D_2)) = 0$  **then**
- 17:  $P$  discards  $ID_U$ , raises a dispute with  $V$  over the logged record, and aborts.
- 18:  $P$  outputs  $ID_U$  and the opened trace  $(CFT, (ts, RID, ID_V), \sigma_{SW,V}, ID_U, D_2)$

**IssueWarrant( $P, J, \text{reason}, \text{aux}, ID_{SW}$ )**

- 1:  $P$  presents  $\text{reason}$  to  $J$ .
- 2: **if**  $\text{reason}$  not legitimate **then**
- 3:  $\perp$   $J$  aborts.
- 4:  $\sigma_{SW} \leftarrow \text{Sign}_{sk_J}(ID_{SW} \parallel \text{reason} \parallel \text{aux})$
- 5: **return**  $\sigma_{SW}$

**ObtainTrail( $P, V, \sigma_{SW}, RID$ )**

- 1: **if**  $RID$  is NULL **then**
- 2:  $\perp$   $P$  buys an anonymous check with id  $RID$ .
- 3:  $P$  sends  $\sigma_{SW}, RID$  to  $V$ .
- 4: **if**  $\sigma_{SW}$  is invalid **then**
- 5:  $\perp$   $V$  aborts.
- 6:  $V$  retrieves  $CFT$  for  $RID$  with params  $(ts, RID, ID_V)$ .
- 7:  $\sigma_{SW,V} \leftarrow \text{Sign}_{sk_V}(ID_{SW} \parallel ts \parallel RID \parallel ID_V \parallel H(CFT))$
- 8: **return**  $(CFT, ts, RID, ID_V, \sigma_{SW,V})$

**PartialDecrypt( $X, val_1, val_2, sk_X$ )**

- 1:  $D_{(1,X)} \leftarrow sk_X \cdot val_1$
- 2:  $D_{(2,X)} \leftarrow sk_X \cdot val_2$
- 3: **return**  $(D_{(1,X)}, D_{(2,X)})$

Fig. 4: CFT anonymity revocation (left) and its subroutines (right).

of the revocation committee is honest, while enabling the revocation committee to learn about the usage records of the suspect. Next, we discuss how the two-phase partial decryption protocol fits into the search by activity threshold scenario.

*G. Searching by Activity Threshold*

A generalization of *search by suspect ID* is to find every ID that appears more than a threshold  $\tau$  number of times, with no suspect fixed in advance. The suspect-ID protocol (Figure 8) does not extend directly: with no reference identifier, the committee would compare one unknown PID against another, and merely blinding the identifiers still leaks the access pattern over the encrypted records—a major privacy risk [91]–[93].

**An MPC-based approach.** At a high level, we avoid this leakage with a *conditional-opening* protocol in which the committee holds shares of the decryption key and learns only which records to open, leaving CFT generation unchanged. The building block is a pairwise *plaintext-equality test* (PET) [94] whose equality witnesses are consumed inside a secure multiparty computation (MPC): the MPC counts, for each CFT, how many others encrypt the same ID and reveals only the per-CFT bit indicating whether that count reaches  $\tau$ . The committee then threshold-decrypts exactly the CFTs whose bit is set, while the non-matching records, the pairwise match pattern, and the counts themselves stay hidden. We defer the full construction, its security argument, and the implementation to Appendix D due to space constraints.

## V. IMPLEMENTATION

This section details the prototype implementations of the CFT generation and anonymity revocation protocols. The implementation source is available in an anonymous repository<sup>3</sup>.

*A. Proof Generation and Verification*

We implemented a zero-knowledge circuit for demonstrating the possession of a valid, digitally signed credential while proving correct encryption of a CFT and legal age constraints ① ②—an important use case of ACs [47]. The credential used in our prototype contains 32 attributes: an upper bound on the number of attributes of the Swiss e-ID (24 attributes [95]), and five of them are used in the circuit’s logic.

We developed two implementations of this proof: a native C++ version built on the Longfellow stack, and a SNARK-oriented circuit implementation. The circuit proves the following statements in zero-knowledge:

- 1) **Credential Validity:** Five attributes (identity components validity timestamps, and birthdate) are proven to belong to the credential by showing membership among the full set of 32 attributes committed in a single hash. The issuer signs this attribute hash, which the prover demonstrates possession of without revealing the attributes themselves, nor the signature.

<sup>3</sup>[https://anonymous.4open.science/r/accountability\\_for\\_acs-7670/](https://anonymous.4open.science/r/accountability_for_acs-7670/)

- 2) **Issuer Signature:** The prover demonstrates possession of a valid signature on the compact attribute hash from the credential issuer (identified by their public key), without revealing the signature itself.
- 3) **Temporal Constraints:** Three checks are enforced:
  - Birth date is before a maximum age threshold ( $\geq 18$ )
  - Credential validity period has begun ( $\text{now} \geq \text{validFrom}$ )
  - Credential has not expired ( $\text{now} \leq \text{validUntil}$ )
- 4) **CFT well-formedness and hardware binding:** The circuit generates two independent random scalars  $r_1$  and  $r_2$ , outputs a trail  $\{C_1, C_2, C_3, C_4\}$  and proves it is well-formed:  $C_1 = r_1 G$ ,  $C_2 = r_2 G$ ,  $C_3 = ID_U + r_1 PK_{CFT}$ , and  $C_4 = \text{Sign}_{sk_U}(H(t, r_2 PK_{CFT}))$ , with  $ID_U$  equal to the identity attribute proven in the credential membership check. Because  $sk_U$  is WSCD-bound and non-extractable,  $C_4$  provides device binding without a separate hardware-signature claim. Stack-specific hash, curve, and signature algorithms are given below. At revocation, the committee recovers  $ID_U$  from  $C_3$  and verifies  $C_4$  against  $H(t, r_2 PK_{CFT})$  using the user's public key.

a) *Standards-based implementation:* This is a native C++ implementation built on the Longfellow stack [13], [96] and standard cryptographic primitives. It uses P-256 for elliptic-curve operations, ECDSA for issuer signatures and for the hardware-held user key used in  $C_4$ , and SHA-256 for hashing. These algorithms are supported on most secure enclaves in smartphones, enabling hardware device binding of private keys. Therefore, they are used in verifiable credential standards such as mobile driving license (mDoc/mDL), and the EUDI and Swiss e-ID.

b) *ZK-friendly implementation:* Longfellow is optimized for its specific use case, but the underlying algorithms produce large proof circuits when used in generic scenarios. We therefore implement a variant using more SNARK-friendly techniques: BabyJubjub curve arithmetic, Poseidon hashing, and EdDSA-style signatures. The implementation is expressed as a circuit description (Circom) and produces witness/proof material using rapidsnark as the prover.

c) *Credential non-revocation proof:* As an optional extension, both stacks can additionally prove that the presented credential is not revoked against a packed status-list Merkle root: the issuer embeds a revocation index in a signed attribute slot, and the circuit proves a Merkle authentication path to a public root with the corresponding bit unset (i.e., the credential is not revoked). The revocation index stays private in order not to make two presentations linkable. We report the composed cost separately in §VI-B and Appendix C.

### B. Anonymity Revocation

We implemented prototypes for all three scenarios of anonymity revocation: Searching by Request ID (Figure 4), Searching by Suspect ID (Figure 8), and Searching by Activity Threshold—both without MPC (Figure 9), and with MPC (Appendix D). We use MP-SPDZ [97] for our MPC-based implementation and run it using the `Semi` protocol, which is

the semi-honest version of MASCOT [98]. The simplifications consist of omitting the warrant generation and trail collection steps, and the signatures creation and verification steps.

Our implementations use the same cryptographic primitives as the zk-friendly implementation described above.

### C. Integration in Digital Identity Stack

Both, the Swiss and EU solutions use the OID4VP (OpenID for Verifiable Presentations) protocol [99] for handling credential requests and presentations [35], [36]. OID4VP provides extension points and profiles to deal with specific formats, trust requirements and transport mechanisms. The EU has already drafted a standard for integrating circuit-based ZKPs with EUDI wallets and OID4VP [38]. We suggest to build on this and define an OID4VP profile with CFT support, which would enable seamless integration of CFT into e-ID systems.

## VI. PRACTICALITY AND EVALUATION

a) *Requirements:* Digital identity systems such as EUDI and the Swiss e-ID run on mobile devices with limited resources and involve direct user interaction, so any overhead added to a credential presentation impacts the user-perceived latency. Thus, if adding CFT raises the time needed for credential presentation from 500ms to 5s, it will not be accepted by users. Yet, a total latency of about 1-2s for a presentation is often considered acceptable [100], [101].

Hence, in this section, we answer the following questions:

- What is the overhead added by CFTs on proving and verification times? (§VI-A)
- How does composing a non-revocation claim with the CFT presentation scale with population size? (§VI-B)
- What is the time taken for anonymity revocation when searching by Request ID? (§VI-D)
- While searching by Suspect ID and by Activity Threshold, how does anonymity revocation scale? (§VI-D)

### A. Proof Generation and Verification

We evaluate the practical performance of the full credential proof described in §V-A. We benchmark both the standards-based and the fully zk-friendly implementations.

The benchmark is run in two distinct environment to capture the intended deployment model: provers run on constrained devices (e.g., smartphones), while verifiers are expected to run on relatively more powerful server hardware. We nevertheless report verifier times in the constrained devices to cover in-person verification, where the verifier itself runs on a smartphone (e.g., checking legal age in a bar). Finally, we compare our CFT-based implementation with a no-CFT variant of the same proof to obtain the overhead of adding an CFT. Both the CFT-based and no CFT based implementation include a device binding proof: while the device binding is incorporated in Elgamal encryption and binding signature in the CFT implementation (point 4 in §V-A), the no CFT variant involves a prover providing a zero knowledge proof on a random challenge under the device key. The comparison

excludes non-revocation claims (§VI-B), so that relative CFT overhead doesn’t depend on population size.

- **Mobile-like environment:** aarch64 machine with 2 CPU cores and 4 GB of RAM (a resource-constrained virtual machine approximating a smartphone, not a physical handset).
- **Server-like environment:** x86\_64 machine with 8 CPU cores and 16 GB of RAM.

Each benchmark was repeated 10 times, and we report mean prover and verifier runtimes in Table IV.

| Machine | Impl.       | Prover |             | Verifier |             |
|---------|-------------|--------|-------------|----------|-------------|
|         |             | No CFT | CFT         | No CFT   | CFT         |
| Mobile  | Standard    | 1959   | 2213 (+13%) | 1472     | 1686 (+15%) |
|         | zk-friendly | 1030   | 1194 (+16%) | 23       | 23 (+0%)    |
| Server  | Standard    | 1200   | 1355 (+13%) | 854      | 976 (+14%)  |
|         | zk-friendly | 314    | 438 (+39%)  | 12       | 13 (+8%)    |

TABLE IV: Performance of the credential proof (in ms), without a non-revocation claim. Columns show mean runtimes without CFT and with CFT for prover and verifier.

1) *Practical Implications:* Measured overhead of adding the CFT components depends on the environment and implementation. For the prover it ranges from 13% to 39%, while verifier overheads span 0% to 15%.

Longfellow is highly optimized for SHA-256 and ECDSA. But the zk-friendly implementation is faster for the prover (about 2 to 4 times faster depending on the environment) and the verifier (about 75 times faster). Thus, if hardware supports both implementations, we recommend the zk-friendly implementation: zk-SNARKs give greater flexibility for building new circuits, and verification is much cheaper, leading to a major win for high-volume verifiers.

These results indicate that CFT is practical to deploy, with further gains expected from ongoing framework improvements. The standards-based implementation result remains somewhat above the ideal target of 2 seconds, but further optimizations could make it viable soon. Detailed performance analysis comparing attribute commitment representations (Merkle trees vs. flat hashing) is provided in Appendix B.

### B. Proof of Credential Non-Revocation

An additional claim that the credential is not revoked at show time can be added to the credential proof. We time that check as a separate composition on top of the age-check+CFT circuit, varying the population size  $N$  on both stacks and machine profiles. Scaling plots and depth- $d$  fits are in Appendix C. On the zk-friendly stack the prover cost grows only gently with Merkle depth ( $d = \log_2(N) - 7$ ) and stays interactive even at an EU-scale upper bound  $N = 2^{29}$  while the verifier cost is constant (about 1.5 s prove on mobile and  $\approx 13$  ms verify on server). Both the prover and the verifier cost grow linearly with the merkle depth for the standards-based stack. At  $N = 2^{29}$  prove costs 6.5 s on mobile and verify costs 2.8 s on server. This gap reflects two effects: Poseidon is much cheaper in-circuit than SHA-256 as the Merkle path

deepens, and Groth16 verification has fixed cost whereas the Longfellow verifier grows with the SHA-256 circuit.

### C. Communication costs of a credential presentation.

A presentation comprises two messages. The verifier sends a request with  $ts$ ,  $RID$ ,  $ID_V$ , policy parameters ( $now$ ,  $maxBirthDate$ ), and the current status-list root (192 B total). The wallet derives  $t$  locally, so the tag is not sent, and the Merkle path for non-revocation stays private. In the other direction the wallet returns the trail  $CFT$  (288 B on both stacks) and the proof  $\pi$ . The sizes below are for our above-mentioned use case (age-check+CFT+non-revocation claim). On the zk-friendly stack the Groth16 proof itself is fixed-size ( $|\pi| = 128$  B for any  $N$ ), so this show is 416 B and end-to-end communication about 608 B. On the standard stack  $|\pi|$  grows with the circuit, and hence with population via the status-list Merkle depth, reaching about 663 KB at Swiss-scale  $N = 2^{24}$  and about 716 KB at EU-scale  $N = 2^{29}$ .

a) *Verifier storage:* Since verifiers must store the trail and the proof for a certain retention period (§III-D), the server-side storage grows with presentation size. On the zk-friendly stack a presentation occupies 416 B (288 B trail plus 128 B proof), i.e., about 152 GB for a one-year retention window at a rate of one million presentations per day. On the standard stack the proof dominates ( $\approx 663$  KB at Swiss scale), amounting to roughly 242 TB per year at the same rate — a substantial burden for high-volume verifiers, and a further reason to prefer the zk-friendly stack when both are available.

### D. Anonymity Revocation

We ran the benchmarks for anonymity revocation 5 on a server-like machine described above, as the committee should have access to better hardware. Each benchmark was repeated 10 times, and we report mean runtimes in milliseconds.

For the “Searching by Request ID” case, the anonymity revocation benchmark resulted in a mean runtime of 21 ms, i.e., a throughput of roughly 48 revocations per second, which is more than sufficient for the expected frequency of revocations in real-world deployments.

For the “Searching by Suspect ID” and “Searching by Activity Threshold” scenarios, we benchmark three techniques: *direct decryption*, which runs `PartialDecrypt` on every trail in scope; *link-then-decrypt*, the two-phase partial decryption of §IV-F and §IV-G; and the *MPC-based* approach of Appendix D. We varied the size of the set of trails considered (between 10 and 8000 trails), and also varied the size of the set considered for the final decryption step of the link-then-decrypt approach (between 10 and 50 percent of the full set of trails size). The results are shown in Figure 5.

As depicted in Figure 5, the time taken for revocation grows linearly with the number of trails to be decrypted for the direct decryption and the link-then-decrypt approach, and quadratically for the MPC-based approach. The standard deviations are too small for the error bars to be visible in the figure. In the link-then-decrypt approach, the time taken also

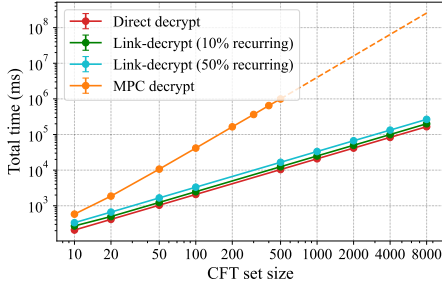


Fig. 5: Total revocation time across the three anonymity revocation techniques as a function of the number of CFTs; dashed lines represent extrapolated values.

grows linearly with the number of trails that reach the second stage of the algorithm.

We fit the benchmark runtimes of the link-then-decrypt approach to a linear model, which gives us the formula:

$$T(N, M) \approx 23 \cdot N + 21 \cdot M,$$

where  $N$  denotes the total number of trails considered and  $M$  denotes the number of "recurring ID", i.e., trails remaining after the filtering step, that will go through the anonymity revocation stage. In the "10% of recurring ID" scenario,  $M = 0.1N$ , and the formula becomes  $T(N) \approx 23 \cdot N + 2.1 \cdot N = 25.1 \cdot N$ . In the "50% of recurring ID" scenario,  $M = 0.5N$ , and the formula becomes  $T(N) \approx 23 \cdot N + 11.5 \cdot N = 34.5 \cdot N$ . The 50% scenario thus takes more time simply because more trails reach the second stage of the link-then-decrypt algorithm.

Opting for the two-stage approach instead of revoking anonymity of all trails adds roughly 2 ms per candidate trail plus an additional 21 ms per trail that reaches the final revocation stage.

For the MPC-based decryption variant, the Search by Activity Threshold case scales as

$$T(N) \approx 8 \cdot (N \cdot (N - 1)/2),$$

which depicts the quadratic computational cost in the MPC-based approach.

## VII. DISCUSSION AND FUTURE WORK

*a) Transparency logs for CFT accesses:* Decentralizing the revocation committee mitigates the chances of anonymity revocation of benign users. However, the system is still non-transparent to the users: they have no direct visibility into when, or how often, their CFTs are opened. A natural extension for transparency is to maintain a CFT search log — with its warrant identifier, verifier, and timestamp — to an append-only, publicly verifiable log, drawing inspiration from Certificate Transparency [102] and CONIKS [103]. Users could either be notified directly whenever a CFT linked to their identity is opened, or receive periodic aggregate reports summarizing CFT accesses. We leave the precise design of the transparency logs for CFTs to future work.

*b) MPC at Scale:* The search by activity threshold may require the opening of thousands of CFTs under MPC. Running the protocol symmetrically across all three parties per record imposes a sizeable cost on the NGO, typically the least-resourced party. A natural mitigation is *asymmetric MPC* [104], in which parties contribute different amounts of work while jointly realizing the functionality with the same security guarantees. The police and judge, both backed by state infrastructure, could handle the heavy computation involved, while the NGO participates with a much lighter footprint. However, Goyal et al. only address asymmetric network requirements; extending asymmetric MPC to support asymmetric compute and storage remains an open problem.

*c) Post-quantum security:* As the EUDI / Swiss e-ID systems will not be quantum-safe upon go-live, they will likely face a migration to post-quantum-cryptography [105], [106] within a few years. The dominant prerequisite — and the actual deployment bottleneck — is hardware support for PQ primitives in secure enclaves and their widespread availability across user devices. Yet, digital ID systems are under less store-now-decrypt-later pressure than bulk data encryption: broken signatures can be replaced by PQ signatures and integrity restored, but lost confidentiality cannot be retroactively repaired. The CFT, being an encrypted identifier stored by verifiers, is an exception. However, expected verifier retention periods are short (6–12 months), and well below the timelines projected for cryptographically relevant quantum computers [107]. A non-compliant verifier deliberately archiving CFTs would re-introduce the risk; CFT-log auditing (§III-E) thus serves a dual role.

Designing a fully PQ-safe CFT is important future work, but the path is quite clear. The institutional design and protocol architecture are agnostic to cryptographic primitives. ECDSA / EdDSA become Dilithium (ML-DSA). ZKPs migrate to lattice-based or hash-based (STARK) backends. The joint-key ElGamal encryption could be replaced by sequential nested PQ encryption under three independent keys. For the two-phase opening, our MPC-based protocol (§IV-G) is naturally PQ-safe: under the 1-out-of-3 honesty assumption, dishonest-majority MPC protocols such as maliciously-secure replicated secret sharing are information-theoretically secure and available off-the-shelf in MP-SPDZ [108].

We expect the performance impact of using PQ-safe components to be significant, requiring detailed analysis.

*d) Dealing with malicious verifiers:* As highlighted in §IV-B, verifiers need to store the proofs and the randomness for all credential shows. These proofs and randomness can be used for preventing malicious verifier behavior (preventing verifiers from not verifying credential shows) in one of the two ways: (i) a sting operation-like approach [63] where the police can buy services from verifiers and ask them to present the proof of storage; (ii) matching the CFT logs with the financial records, which the verifiers are already required to store for legal compliance [109]–[112]. The matching protocol for the latter approach does not leak anything about users because of unlinkability but this matching protocol can be run using



privacy-enhancing technologies to eliminate any leakage about verifiers as well; we leave this for future work.

*e) Cryptographically enforcing warrant scope:* One could attempt to cryptographically enforce the requirements stored in the auxiliary information (aux) across all the parties, which we believe is a challenging task and we leave it for future work. However, we highlight that this cryptographic enforcement does not bring any new security guarantees. This is because all three parties of the anonymity revocation committee along with the relevant verifiers need to agree to run the anonymity revocation protocol on a set of CFTs — it does not matter if there is a cryptographic enforcement of warrant scope or not.

## VIII. RELATED WORK

*a) Anonymity Revocation in AC:* ACs were introduced by Chaum [1] and since then, many works have followed focusing on efficiency and privacy [2], [30]–[34]. Camenisch and Lysyanskaya [2] introduced *anonymity revocation* via a centralized authority; later work made this authority third-party-auditable [113] and then user-auditable [27]. Yet revocation has remained optional in ACs and is absent from today’s national identity systems. CFT revives this goal, now made urgent by nationwide deployment. The most direct prior work is PAPR [28], with a concurrent proposal by Daza et al. [29]. CFT differs from PAPR in three ways: (i) PAPR restricts itself to linkable showings; CFT treats unlinkability as a precondition. (ii) PAPR de-anonymizes all credential shows of a user; CFT is scoped to the warrant. (iii) PAPR prevents misuse only by detection; CFT prevents it structurally via separation of powers. PAPR’s bulletin-board transparency could nonetheless be combined with CFT. Rate-limiting ACs [114] prevent only over-use, offering no way to investigate other misbehavior.

*b) Group Signatures and Their Variants:* Group signatures [10], [11], [39] let any member sign anonymously to prove membership, while a designated *open* protocol revokes a signer’s anonymity—a natural fit for accountable anonymity. Opening, however, is handled typically by the centralized group manager, and the scheme’s setup is not ECDSA-compatible, a requirement for national e-IDs. Threshold group signatures [40] decentralize opening across several parties, but do not eliminate the standardization issue. Traceable signatures [41]–[43], along with related bifurcated [43], hidden ID-based signatures [44], and identity escrow [37], [45], add finer-grained privacy properties to group signatures. However, they fall short in standardization compliance and providing generic revocation ability such as search by activity threshold. As highlighted in Table I, none of these primitives simultaneously provides unlinkability, multi-party opening, and standardization compliance—precisely the gap that CFT fills.

*c) Accountability for State Processes:* Green et al. [115] propose an abuse-resistant law enforcement. CFT differs by targeting ACs rather than encrypted communications, using only standard primitives rather than witness encryption, and integrating institutional separation of powers—a necessity for

practicality (§III-C). Goldwasser et al. [116] address public accountability for “secret” state processes and Frankle et al. [117] make warrant processes auditable in aggregate without revealing individual targets. CFT extends this idea from accountable issuance to warrant *execution* in ACs.

*d) Cryptographic Pseudonyms:* Mayrhofer et al. [118] present cryptographic pseudonyms for European Identity Wallet (EUDIW) and accountability can be ensured in this setting as verifiers bind accounts to fixed pseudonyms of holders. While this approach demotivates selling numerous proofs, it requires verifiers to track (anonymous) holders using personal accounts. Additionally, the approach does not allow anonymity revocation of misbehaving users or stopping their activity on other sites as pseudonyms are unique to each verifier, it is impossible to build collaborative blocklists.

*e) Others:* Anonymous tokens have been extended with a hidden metadata bit using algebraic MACs [119], but one bit is insufficient to encode a CFT. Zcash [120] allows opening private transactions via viewing keys, but these keys are user-controlled and must be voluntarily shared with authorities. Tsang et al. [121] blacklist anonymous credentials in a decentralized way, but blacklisting does not de-anonymize misbehaving users.

TruAge [122] is a solution developed in the US for age verification in stores (points of sales), based on driving license attributes. It uses encrypted, one-time digital tokens and provides admissible proof-of-age verification appended to retailers’ transaction logs, which can be unlocked under subpoena and submitted as evidence. While being an industry-driven solution for a specific use case, TruAge demonstrates the importance of privacy-preserving token presentation subjected to anonymity revocation through subpoenas, as intended by our CFT logs and the revocation committee process.

## IX. CONCLUSIONS

In this paper, we first argue why accountability must be an integral part of designing anonymous credential-based national digital identities systems. To this end, we introduce the *cryptographic forensic trail (CFT)*, a mechanism enabling controlled and transparent revocation of anonymity through a multi-party protocol with democratic checks and balances. We design and implement several CFT protocol variants using state-of-the-art cryptographic primitives. Our evaluation demonstrates that practical, privacy-preserving accountability mechanisms for national identity systems are within reach.

## ACKNOWLEDGMENTS

## ETHICS CONSIDERATIONS

To every credential presentation, the CFT attaches cryptographic material that can be used to identify the presenting user under specified conditions (targeted warrants). This deliberately weakens the unlinkability property of these presentations and hence affects citizen privacy. The experiments in this paper were performed in the lab and did not involve real user data. In the following, we discuss implications of the CFT if it were deployed on national scale.

We believe that neither the Swiss e-ID Act [123] nor the EUDI Regulation [124] currently provide a legal basis for warrant-bound anonymity revocation of credential presentations, and existing telecommunications surveillance law (BÜPF [74], ePrivacy Directive [125]) may not cover this operation, since credential presentations are not communications in the sense these instruments define. This question requires further investigation. Therefore, deploying CFT could require new legislation, defining the institutional roles, and integrating with judicial-review mechanisms. We view this legislative dependency as a feature, not a bug: such a critical mechanism requires democratic deliberation and should not be available to executive action alone. The CFT proposes what the cryptographic substrate of such regulation could look like if designed with accountability as a first-class requirement.

While the CFT affects citizen privacy, the realistic alternative to CFT is not unconditional anonymity for all users. As we have discussed throughout the paper (see §I–§III), a lack of accountability may lead to an overall worse level of privacy, also for the vast majority of users who never become the subject of a warrant. A balanced discussion of ethical aspects must also address implications of lacking accountability in national digital identity. As we have shown, proof proxy attacks may undermine authenticity of identity proofs, even if credentials are non-transferable and hardware-bound. Legislation depending on these checks (like age verification) may be rendered obsolete, leaving society with the overhead but not the protective effects of digital credentials. If it is possible to cheat with identity proofs and get away, a false sense of security may arise, eventually eroding trust in the overall system.

CFT has some inherent limitations. It always identifies the signing account holder (Eve in our example), which is not necessarily the (only) wrongdoer. Alice, who consumes an illegal service, is not identified by CFT. In case private keys or devices are stolen or people are coerced, the victim is under pressure to prove their innocence. As is the case with misused electronic signatures, this would require police reporting as well as forensic analysis of platform audit trails and session metadata. We recognize that a principled objection remains: any anonymity revocation capability, however constrained, may eventually be abused (e.g., by a future government), and the ethically correct response may be to refuse to design it. We take this view seriously; our disagreement is empirical rather than normative. CFT’s institutional guarantees are bounded by

the assumptions on which they rest: a functioning separation of powers and an independent civil-society co-signer with a democratic mandate. We do not recommend CFT deployment where these assumptions fail, and we do not claim to have resolved all ethical questions the design raises; these must eventually be addressed through democratic debate.

## OPEN SCIENCE

Implementations of the CFT algorithms and evaluation scripts are publicly available at [https://anonymous.4open.science/r/accountability\\_for\\_acs-7670](https://anonymous.4open.science/r/accountability_for_acs-7670).

## USE OF AI TOOLS

The authors used generative AI-based tools to improve flow and awkward phrasing. AI-based tools were used to search for additional related work and for pre-submission review.

We have manually verified and are responsible for the accuracy, originality, and integrity of the output of all AI-based tools.

## REFERENCES

- [1] D. Chaum, “Security without identification: Transaction systems to make big brother obsolete,” *Communications of the ACM*, vol. 28, no. 10, pp. 1030–1044, 1985.
- [2] J. Camenisch and A. Lysyanskaya, “An efficient system for non-transferable anonymous credentials with optional anonymity revocation,” in *International conference on the theory and applications of cryptographic techniques*. Springer, 2001, pp. 93–118.
- [3] T. F. C. of Switzerland, “e-id act,” 2025, on 28 September 2025, Swiss voters approved a state-issued e-ID after rejecting a private scheme in 2021. [Online]. Available: <https://www.admin.ch/gov/en/st/art/documentation/votes/20250928/e-id-act.html>
- [4] E. Commission, “European digital identity (eudi) regulation,” 2024, explains that eIDAS 2.0 requires member states to provide an EU Digital Identity wallet by 2026 and describes the obligations and goals. [Online]. Available: <https://digital-strategy.ec.europa.eu/en/policies/eudi-regulation>
- [5] F. Weissbaum, A. F. Sang, A. Höss, and J. Niestroj, “Key Management for e-ID - Batch Issuance and Renewal V 1.1,” <https://github.com/swi-yu-admin-ch/community/blob/main/tech-concepts/e-id-key-management-batch-issuance-and-renewal.md>, 2025.
- [6] E. D. P. Supervisor, “Techdispatch – digital identity wallets,” 2025, notes that anonymous credentials can mitigate over-disclosure and linkability and are not yet widely adopted. [Online]. Available: [https://www.edps.europa.eu/data-protection/our-work/publications/techdispatch/2025-12-15-techdispatch-32025-digital-identity-wallets\\_en](https://www.edps.europa.eu/data-protection/our-work/publications/techdispatch/2025-12-15-techdispatch-32025-digital-identity-wallets_en)
- [7] S. G. Popescu, “Swiss e-ID: Use cases, harms, opportunities,” 2026. [Online]. Available: <https://infoscience.epfl.ch/entities/publication/25a1f247-3f5e-4967-b4d1-3dabb0eb7ed5>
- [8] C. Baum, O. Blazy, J. Camenisch, J.-H. Hoepman, E. Lee, A. Lehmann, A. Lysyanskaya, R. Mayrhofer, H. Montgomery, N. K. Nguyen *et al.*, “Cryptographers’ feedback on the eu digital identity’s ARF,” *Tech. Rep.*, 2024.
- [9] “Joint statement of scientists and NGOs on the EU’s proposed eIDAS reform,” <https://eidas-open-letter.org/>, November 2023, signed by 504 scientists and researchers as of November 8, 2023.
- [10] D. Boneh, X. Boyen, and H. Shacham, “Short group signatures,” in *Advances in Cryptology – CRYPTO 2004*, ser. Lecture Notes in Computer Science, vol. 3152. Springer, 2004, pp. 41–55.
- [11] M. H. Au, W. Susilo, and Y. Mu, “Constant-size dynamic  $k$ -taa,” in *International conference on security and cryptography for networks*. Springer, 2006, pp. 111–125.
- [12] S. Tessaro and C. Zhu, “Revisiting bbs signatures,” in *Annual International Conference on the Theory and Applications of Cryptographic Techniques*. Springer, 2023, pp. 691–721.
- [13] M. Frigo and abhi shelat, “Anonymous credentials from ECDSA,” *Cryptology ePrint Archive*, Paper 2024/2010, 2024. [Online]. Available: <https://eprint.iacr.org/2024/2010>

- [14] M. Babel and J. Sedlmeir, "Bringing data minimization to digital wallets at scale with general-purpose zero-knowledge proofs," *arXiv preprint arXiv:2301.00823*, 2023.
- [15] "EUDI Architecture and Reference Framework - Discussion Paper G - Zero Knowledge Proof," <https://github.com/eu-digital-identity-wallet/eudi-doc-architecture-and-reference-framework/discussions/408>, 2025.
- [16] A. Lehmann, "EU digital identity and anonymous credentials - a happy end?" Talk given at RWC 2025, Video at <https://youtu.be/UpQHWObCx4I>, 2025.
- [17] C. Paquin, G.-V. Policharla, and G. Zaverucha, "Crescent: stronger privacy for existing credentials," *Cryptology ePrint Archive*, 2024.
- [18] A. Lehmann and A. Zacharakis, "Device binding for anonymous credentials on legacy phones," *Cryptology ePrint Archive*, 2026.
- [19] R. Mayrhofer, B. Preneel, D. Aranha, O. Blazy, A. Lehmann *et al.*, "Joint statement of security and privacy scientists and researchers on Age Assurance," <https://csa-scientist-open-letter.org/ageverif-Feb2026>, February 2026.
- [20] S. E. Landau, *Listening in: Cybersecurity in an insecure age*. Yale University Press, 2017.
- [21] "Proposal for a Regulation of the European Parliament and of the Council laying down rules to prevent and combat child sexual abuse," [https://cdn.netzpolitik.org/wp-upload/2025/07/2025-07-24\\_Council\\_P\\_residency\\_LEWP\\_CSA-R\\_Compromise-texts\\_11596.pdf](https://cdn.netzpolitik.org/wp-upload/2025/07/2025-07-24_Council_P_residency_LEWP_CSA-R_Compromise-texts_11596.pdf), 7 2025.
- [22] "Joint statement of scientists and researchers on the EU Presidency's new proposal for the Child Sexual Abuse Regulation," <https://csa-scientist-open-letter.org/Sep2025>, 2025.
- [23] C. Jones, "Signal will withdraw from Sweden if encryption-busting laws take effect," [https://www.theregister.com/2025/02/26/signal\\_will\\_withdraw\\_from\\_sweden/](https://www.theregister.com/2025/02/26/signal_will_withdraw_from_sweden/), February 2025.
- [24] J. Mullin, "A Win for Encryption: France Rejects Backdoor Mandate," <https://www.eff.org/deeplinks/2025/03/win-encryption-france-rejects-backdoor-mandate>, March 2025.
- [25] B. Hoeisen, "Switzerland's Privacy and Encryption Under Attack: Proposed Surveillance Laws Threaten Fundamental Rights and Cripples Encryption," <https://www.isoc.ch/swiss-surveillance-ordinance-encryption-threat-vupf-oscpt/>, May 2025.
- [26] Euronews, "Apple challenges the UK's second attempt to gain access to iCloud data," <https://www.euronews.com/next/2026/08/04/apple-challenges-the-uks-second-attempt-to-gain-access-to-icloud-data>, August 2026.
- [27] J. Camenisch and A. Lehmann, "Privacy-preserving user-auditable pseudonym systems," in *2017 IEEE European Symposium on Security and Privacy (EuroS&P)*. IEEE, 2017, pp. 269–284.
- [28] J. Brorsson, B. David, L. Gentile, E. Pagnin, and P. S. Wagner, "Papir: Publicly auditable privacy revocation for anonymous credentials," in *Cryptographers' Track at the RSA Conference*. Springer, 2023, pp. 163–190.
- [29] V. Daza, A. Haque, A. Scafuro, A. Zacharakis, and A. Zapico, "Mutual accountability layer: accountable anonymity within accountable trust," in *International Symposium on Cyber Security, Cryptology, and Machine Learning*. Springer, 2022, pp. 318–336.
- [30] J. Camenisch and E. Van Herreweghen, "Design and implementation of the idemix anonymous credential system," in *Proceedings of the 9th ACM Conference on Computer and Communications Security*, ser. CCS '02. New York, NY, USA: Association for Computing Machinery, 2002, p. 21–30. [Online]. Available: <https://doi.org/10.1145/586110.586114>
- [31] J. Camenisch and A. Lysyanskaya, "Signature schemes and anonymous credentials from bilinear maps," in *Annual international cryptology conference*. Springer, 2004, pp. 56–72.
- [32] M. Belenkiy, M. Chase, M. Kohlweiss, and A. Lysyanskaya, "P-signatures and noninteractive anonymous credentials," in *Theory of cryptography conference*. Springer, 2008, pp. 356–374.
- [33] M. Chase, S. Meiklejohn, and G. Zaverucha, "Algebraic macs and keyed-verification anonymous credentials," in *Proceedings of the 2014 ACM SIGSAC conference on computer and communications security*, 2014, pp. 1205–1216.
- [34] M. Rosenberg, J. White, C. Garman, and I. Miers, "zk-creds: Flexible anonymous credentials from zkSNARKs and existing identity infrastructure," in *2023 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2023, pp. 790–808.
- [35] "European Digital Identity Architecture and Reference Framework (ARF)," <https://eudi.dev/latest/architecture-and-reference-framework-main/>, 2026.
- [36] "Swiss e-ID Technology Stack," <https://swiyu-admin-ch.github.io/technology-stack/>, 2026.
- [37] J. Kilian and E. Petrank, "Identity escrow," in *Annual International Cryptology Conference*. Springer, 1998, pp. 169–185.
- [38] "Specification for the implementation of Zero-Knowledge Proofs based on arithmetic circuits in the EUDI Wallet," <https://github.com/eu-digital-identity-wallet/eudi-doc-standards-and-technical-specifications/blob/main/docs/technical-specifications/ts13-zkSNARKs.md>, EU, January 2026.
- [39] M. Abdalla and B. Warinschi, "On the minimal assumptions of group signature schemes," in *Information and Communications Security – ICICS 2004*, ser. Lecture Notes in Computer Science, vol. 3269. Springer, 2004, pp. 1–13.
- [40] J. Camenisch, M. Drijvers, A. Lehmann, G. Neven, and P. Towa, "Short threshold dynamic group signatures," in *Security and Cryptography for Networks – SCN 2020*, ser. Lecture Notes in Computer Science, vol. 12238. Springer, 2020, pp. 401–423, iACR ePrint 2020/016.
- [41] A. Kiayias, Y. Tsiounis, and M. Yung, "Traceable signatures," in *Advances in Cryptology – EUROCRYPT 2004*, ser. Lecture Notes in Computer Science, vol. 3027. Springer, 2004, pp. 571–589.
- [42] M. Abe, S. S. Chow, K. Haralambiev, and M. Ohkubo, "Double-trapdoor anonymous tags for traceable signatures," *International journal of information security*, vol. 12, no. 1, pp. 19–31, 2013.
- [43] B. Libert, K. Nguyen, T. Peters, and M. Yung, "Bifurcated signatures: folding the accountability vs. anonymity dilemma into a single private signing scheme," in *Annual International Conference on the Theory and Applications of Cryptographic Techniques*. Springer, 2021, pp. 521–552.
- [44] A. Kiayias and H.-S. Zhou, "Hidden identity-based signatures," in *International Conference on Financial Cryptography and Data Security*. Springer, 2007, pp. 134–147.
- [45] J. Camenisch and A. Lysyanskaya, "An identity escrow scheme with appointed verifiers," in *Annual International Cryptology Conference*. Springer, 2001, pp. 388–407.
- [46] R. Arnold and D. Longley, "Zero-knowledge proofs do not solve the privacy-trust problem of attribute-based credentials: What if Alice is evil?" *IEEE Communications Standards Magazine*, vol. 3, no. 4, pp. 26–31, 2019.
- [47] C. Knabenhans, S. Veitch, M. Raynal, T. Stadler, S. Chatel, W. Lueks, and C. Troncoso, "On the (privacy) harms of the European digital identity framework," *Cryptology ePrint Archive*, Paper 2026/867, 2026. [Online]. Available: <https://eprint.iacr.org/2026/867>
- [48] S. Adler, Z. Hitzig, S. Jain, C. Brewer, W. Chang, R. DiResta, E. Lazarin, S. McGregor, W. Seltzer, D. Siddarth *et al.*, "Personhood credentials: Artificial intelligence and the value of privacy-preserving tools to distinguish who is real online," *arXiv preprint arXiv:2408.07892*, 2024.
- [49] K. Soska and N. Christin, "Measuring the longitudinal evolution of the online anonymous marketplace ecosystem," in *24th USENIX security symposium (USENIX security 15)*, 2015, pp. 33–48.
- [50] N. Christin, "Traveling the silk road: A measurement analysis of a large anonymous online marketplace," in *Proceedings of the 22nd international conference on World Wide Web*, 2013, pp. 213–224.
- [51] Federal Bureau of Investigation, "AlphaBay Takedown," <https://www.fbi.gov/news/stories/alphabay-takedown>, 2017, alphaBay served over 200,000 users and 40,000 vendors, with listings for illegal drugs, stolen identity documents, malware, firearms, and fraudulent services; taken down in Operation Bayonet.
- [52] Financial Action Task Force, "Illicit Financial Flows from Cyber-Enabled Fraud," Financial Action Task Force (FATF), Tech. Rep., November 2023. [Online]. Available: <https://www.fatf-gafi.org/content/dam/fatf-gafi/reports/Illicit-financial-flows-cyber-enabled-fraud.pdf>
- [53] U.S. National Counterterrorism Center, "Identifying and Preventing Illicit Use of Cryptocurrency by Terrorists," Joint Counterterrorism Assessment Team (JCAT), Tech. Rep., 2024. [Online]. Available: [https://www.dni.gov/files/NCTC/documents/jcat/firstresponderstoolbox/119s\\_-\\_First\\_Responders\\_Toolbox\\_-\\_Identifying\\_and\\_Preventing\\_Illicit\\_Use\\_of\\_Cryptocurrency\\_by\\_Terrorists.pdf](https://www.dni.gov/files/NCTC/documents/jcat/firstresponderstoolbox/119s_-_First_Responders_Toolbox_-_Identifying_and_Preventing_Illicit_Use_of_Cryptocurrency_by_Terrorists.pdf)
- [54] F. Jessica, "Age-verified Roblox accounts are already being sold on eBay," <https://www.dexerto.com/roblox/age-verified-roblox-accounts-are-already-being-sold-on-ebay-3302680/>, January 2026.

- [55] “Building a Swiss Digital Trust Ecosystem – Perspectives around an e-ID ecosystem in Switzerland,” <https://digitalswitzerland.com/building-a-swiss-digital-trust-ecosystem/>, 2022.
- [56] A. Chan, C. Ezell, M. Kaufmann, K. Wei, L. Hammond, H. Bradley, E. Blumke, N. Rajkumar, D. Krueger, N. Kolt *et al.*, “Visibility into ai agents,” in *Proceedings of the 2024 ACM conference on fairness, accountability, and transparency*, 2024, pp. 958–973.
- [57] J. Hesse, N. Singh, and A. Sorniotti, “How to bind anonymous credentials to humans,” in *32nd USENIX Security Symposium (USENIX Security 23)*, 2023, pp. 3047–3064.
- [58] F. Egger, “Security analysis of the swiss e-id and trust infrastructure,” [https://github.com/user-attachments/files/21157739/Security\\_Analysis\\_of\\_the\\_Swiss\\_e\\_ID\\_Trust\\_Infrastructure.pdf](https://github.com/user-attachments/files/21157739/Security_Analysis_of_the_Swiss_e_ID_Trust_Infrastructure.pdf), July 2025.
- [59] D. Mombelli, “General-Purpose Zero-Knowledge Proofs for Verifiable Credentials,” Master’s thesis, ETH Zurich, March 2025, available at [https://ethz.ch/content/dam/ethz/special-interest/infk/inst-infsec/applied-crypto/education/theses/masters-thesis\\_damiano-mombelli.pdf](https://ethz.ch/content/dam/ethz/special-interest/infk/inst-infsec/applied-crypto/education/theses/masters-thesis_damiano-mombelli.pdf).
- [60] A. Barua, M. A. Al Alamin, M. S. Hossain, and E. Hossain, “Security and privacy threats for bluetooth low energy in iot and wearable devices: A comprehensive survey,” *IEEE Open Journal of the Communications Society*, vol. 3, pp. 251–281, 2022.
- [61] Swiss Confederation, “Swiss Criminal Procedure Code (StPO) of 5 October 2007, SR 312.0,” <https://www.fedlex.admin.ch/eli/cc/2010/267/en>, 2011, arts. 269–279 require a judicial order for surveillance of telecommunications and traffic data.
- [62] European Parliament and Council of the European Union, “Directive (EU) 2016/680 on the protection of natural persons with regard to the processing of personal data by competent authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences,” <https://eur-lex.europa.eu/eli/dir/2016/680/oj>, 2016, law Enforcement Directive; requires investigative access to be based on Union or Member State law, including prior judicial authorisation where applicable.
- [63] G. R. Newman, “Sting operations,” U.S. Department of Justice, Office of Justice Programs, Tech. Rep., Oct. 2007.
- [64] Congressional Research Service, Library of Congress, “Constitution Annotated: Fourth Amendment – Search and Seizure,” <https://constitution.congress.gov/constitution/amendment-4/>, 2024, official annotated U.S. Constitution; historical background, doctrinal development, and Supreme Court case law.
- [65] Council of Europe, “European Convention on Human Rights, Article 8 – Right to respect for private and family life,” [https://www.echr.coe.int/documents/d/echr/convention\\_eng](https://www.echr.coe.int/documents/d/echr/convention_eng), 1950.
- [66] noyb – European Center for Digital Rights, “About noyb: an independent, non-profit organisation enforcing data protection rights,” <https://noyb.eu/en/about-us>, 2023, accessed: 2026-05-23.
- [67] EDRI – European Digital Rights, “About edri: the biggest european network defending rights and freedoms online,” <https://edri.org/>, 2026, accessed: 2026-05-23.
- [68] European Digital Rights (EDRI) and 47 civil society organisations, “Open letter: High-risk lists must not become an excuse to abandon fundamental rights – joint civil society statement on the Council’s CSA Regulation proposal,” <https://edri.org/our-work/open-letter-high-risk-lists-must-not-become-an-excuse-to-abandon-fundamental-rights/>, 2024.
- [69] Electronic Frontier Foundation, “About eff: Member-supported and independent,” <https://www.eff.org/about>, 2024, accessed: 2026-05-23.
- [70] AlgorithmWatch, “About algorithmwatch: a non-governmental, non-profit organisation evaluating algorithmic decision-making,” <https://algorithmwatch.org/en/>, 2024, accessed: 2026-05-28.
- [71] Digitale Gesellschaft, “Digitale gesellschaft – swiss civil society organisation on digital rights, e-id, and surveillance,” <https://www.digitale-gesellschaft.ch/>, 2024, accessed: 2026-05-28.
- [72] Chaos Computer Club, “About the CCC: Europe’s largest association of hackers,” <https://www.ccc.de/en/club>, 2024, accessed: 2026-05-28.
- [73] The Tor Project, “About the Tor project: independent 501(c)(3) non-profit advancing privacy and anonymity online,” <https://www.torproject.org/about/history/>, 2024, accessed: 2026-05-28.
- [74] Swiss Confederation, “Federal Act on the Surveillance of Postal and Telecommunications Traffic (BÜPF/LSCPT), SR 780.1,” <https://www.fedlex.admin.ch/eli/cc/2018/30/en>, 2018, art. 26 obliges telecommunications service providers to retain communications meta-data (subscriber, traffic, and location data) for six months.
- [75] French Republic, “Code des postes et des communications électroniques, Art. L34-1, and Décret n° 2021-1361 of 20 October 2021,” <https://www.legifrance.gouv.fr/jorf/id/JORFTEXT000044229711>, 2021, obliges electronic communications operators to retain civil identity and contract data for the duration of the contract plus one year, and (on Prime Minister’s order in case of serious threat) traffic and location data for one year, for the purposes of investigating criminal offences.
- [76] Court of Justice of the European Union, “La Quadrature du Net and Others, Case C-470/21, Grand Chamber judgment of 30 April 2024,” <https://curia.europa.eu/juris/document/document.jsf?docid=285405>, 2024, held that general retention of IP addresses for fighting criminal offences is permissible under the ePrivacy Directive, provided strict safeguards are in place.
- [77] “Federal law (classified compilation) — 2018/32 (english edition),” <https://www.fedlex.admin.ch/eli/cc/2018/32/en>, Swiss Federal Chancellery, 2018, published in the Classified Compilation of Swiss Federal Legislation. Accessed: 2026-01-07. [Online]. Available: <https://www.fedlex.admin.ch/eli/cc/2018/32/en>
- [78] Netzpolitik, “Internes dokument: Eu-staaten fordern ein jahr vorratsdatenspeicherung für internet-dienste wie messenger,” <https://netzpolitik.org/2025/internes-dokument-eu-staaten-fordern-ein-jahr-vorratsdatenspeicherung-fuer-internet-dienste-wie-messenger/>, December 2025, accessed: 2026-01-07.
- [79] Y. Lindell and B. Pinkas, “An efficient protocol for secure two-party computation in the presence of malicious adversaries,” in *Advances in Cryptology – EUROCRYPT 2007*. Springer, 2007, pp. 52–78.
- [80] Google, “Play Integrity API,” <https://developer.android.com/google/play/integrity>, 2024, accessed: 2026-05-21.
- [81] Apple Inc., “Establishing your app’s integrity,” <https://developer.apple.com/documentation/devicecheck/establishing-your-app-s-integrity>, 2024, accessed: 2026-05-21.
- [82] H. Abelson, R. Anderson, S. M. Bellovin, J. Benaloh, M. Blaze, W. W. Diffie, J. Gilmore, M. Green, S. Landau, P. G. Neumann *et al.*, “Keys under doormats,” *Communications of the ACM*, vol. 58, no. 10, pp. 24–26, 2015.
- [83] H. Abelson, R. Anderson, S. M. Bellovin, J. Benaloh, M. Blaze, W. Diffie, J. Gilmore, P. G. Neumann, R. L. Rivest, J. I. Schiller *et al.*, “The risks of key recovery, key escrow, and trusted third-party encryption,” 1997.
- [84] S. Checkoway, J. Maskiewicz, C. Garman, J. Fried, S. Cohnsey, M. Green, N. Heninger, R.-P. Weinmann, E. Rescorla, and H. Shacham, “A systematic analysis of the juniper dual ec incident,” in *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*, 2016, pp. 468–479.
- [85] CISA, “Countering Chinese State-Sponsored Actors Compromise of Networks Worldwide to Feed Global Espionage System,” <https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-239a>, 2025.
- [86] S. Masson, A. Sanso, and Z. Zhang, “Bandersnatch: a fast elliptic curve built over the BLS12-381 scalar field,” *Cryptology ePrint Archive*, Paper 2021/1152, 2021. [Online]. Available: <https://eprint.iacr.org/2021/1152>
- [87] B. WhiteHat, M. Bellés, and J. Baylina, “ERC-2494: Baby Jubjub Elliptic Curve,” *Ethereum Improvement Proposals*, Jan. 2020, accessed: 2026-05-17. [Online]. Available: <https://eips.ethereum.org/EIPS/eip-2494>
- [88] S. Pohlig and M. Hellman, “An improved algorithm for computing logarithms over  $\mathbb{F}(p)$  and its cryptographic significance (corresp.),” *IEEE Transactions on Information Theory*, vol. 24, no. 1, pp. 106–110, 1978.
- [89] J. Groth, “On the size of pairing-based non-interactive arguments,” in *Annual international conference on the theory and applications of cryptographic techniques*. Springer, 2016, pp. 305–326.
- [90] A. Segal, B. Ford, and J. Feigenbaum, “Catching bandits and only bandits: Privacy-Preserving intersection warrants for lawful surveillance,” in *4th USENIX Workshop on Free and Open Communications on the Internet (FOCI 14)*. San Diego, CA: USENIX Association, Aug. 2014. [Online]. Available: <https://www.usenix.org/conference/foci14/workshop-program/presentation/segal>
- [91] M. S. Islam, M. Kuzu, and M. Kantarcioglu, “Access pattern disclosure on searchable encryption: Ramification, attack and mitigation,” in *NDSS*, vol. 20, 2012, p. 12.
- [92] P. Grubbs, M.-S. Lacharité, B. Minaud, and K. G. Paterson, “Learning to reconstruct: Statistical learning theory and encrypted database



- attacks,” in *IEEE Symposium on Security and Privacy (S&P) 2019*, 2019.
- [93] G. Kellaris, G. Kollios, K. Nissim, and A. O’neill, “Generic attacks on secure outsourced databases,” in *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*, 2016, pp. 1329–1340.
- [94] M. Jakobsson and A. Juels, “Mix and match: Secure function evaluation via ciphertexts,” in *International Conference on the Theory and Application of Cryptology and Information Security (ASIACRYPT)*. Springer, 2000, pp. 162–177.
- [95] Swiss Federal Department of Justice and Police. (2026) Beta credential service (bcs) - request a beta-id. Accessed: 2026-05-24. [Online]. Available: <https://www.bcs.admin.ch/bcs-web/#/beta-id/create>
- [96] M. Frigo and abhi shelat, “Longfellow ZK Github Repository,” <https://github.com/google/longfellow-zk>, 2025.
- [97] M. Keller, “Mp-spdz: A versatile framework for multi-party computation,” in *Proceedings of the 2020 ACM SIGSAC conference on computer and communications security*, 2020, pp. 1575–1590.
- [98] M. Keller, E. Orsini, and P. Scholl, “Mascot: faster malicious arithmetic secure computation with oblivious transfer,” in *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*, 2016, pp. 830–842.
- [99] O. Terbu, T. Lodderstedt, K. Yasuda, D. Fett, and J. Heenan, “OpenID for Verifiable Presentations 1.0,” [https://openid.net/specs/openid-4-verifiable-presentations-1\\_0.html](https://openid.net/specs/openid-4-verifiable-presentations-1_0.html), OpenID, July 2025.
- [100] F. F.-H. Nah, “A study on tolerable waiting time: how long are web users willing to wait?” *Behaviour & Information Technology*, vol. 23, no. 3, pp. 153–163, 2004.
- [101] J. Nielsen, “Response times: The 3 important limits,” <https://www.nn-group.com/articles/response-times-3-important-limits/>, January 1993, accessed: 2026-05-30.
- [102] B. Laurie, A. Langley, and E. Kasper, “Certificate Transparency,” in *RFC 6962, Internet Engineering Task Force (IETF)*, 2013.
- [103] M. S. Melara, A. Blankstein, J. Bonneau, E. W. Felten, and M. J. Freedman, “CONIKS: Bringing Key Transparency to End Users,” in *24th USENIX Security Symposium*, 2015, pp. 383–398.
- [104] V. Goyal, C.-D. Liu-Zhang, and R. Ostrovsky, “Asymmetric multi-party computation,” *Cryptology ePrint Archive*, 2023.
- [105] CISA/NSA, “Quantum-Readiness: Migration to Post-Quantum Cryptography,” <https://www.cisa.gov/resources-tools/resources/quantum-readiness-migration-post-quantum-cryptography>, August 2023.
- [106] Federal Office for Information Security (BSI), “Quantum-safe cryptography – fundamentals, current developments and recommendations,” <https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/Brochure/quantum-safe-cryptography.html>, May 2022.
- [107] M. Mosca and M. Piani, “Quantum Threat Timeline Report,” <https://globalriskinstitute.org/publication/quantum-threat-timeline-report-2025b/>, 2025.
- [108] M. Keller, “Mp-spdz: A versatile framework for multi-party computation,” in *Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2020, pp. 1575–1590.
- [109] Swiss Confederation, “Federal Act on the Amendment of the Swiss Civil Code (Part Five: The Code of Obligations), SR 220,” [https://www.fedlex.admin.ch/eli/cc/27/317\\_321\\_377/en](https://www.fedlex.admin.ch/eli/cc/27/317_321_377/en), 1911, art. 957–958f oblige undertakings to keep accounting records; Art. 958f requires accounting records and vouchers, together with the annual report and audit report, to be retained for ten years.
- [110] —, “Federal Act on Value Added Tax (VAT Act), SR 641.20,” <https://www.fedlex.admin.ch/eli/cc/2009/615/en>, 2009, art. 70 requires taxable persons to retain books of account, receipts, and business documents until the tax claim prescribes, applying Art. 958f of the Code of Obligations (ten years); business documents relating to immovable goods must be retained for 20 years.
- [111] Council of the European Union, “Council Directive 2006/112/EC on the common system of value added tax,” <https://eur-lex.europa.eu/eli/dir/2006/112/oj>, 2006, art. 244 obliges every taxable person to store copies of all invoices issued and received; Art. 247 leaves the retention period to Member States (typically 6–10 years).
- [112] Federal Republic of Germany, “Handelsgesetzbuch (HGB) – German Commercial Code, § 257,” [https://www.gesetze-im-internet.de/hgb/\\_257.html](https://www.gesetze-im-internet.de/hgb/_257.html), 2025, obliges merchants to retain commercial books, inventories, and annual accounts for ten years, accounting vouchers (Buchungsbelege) for eight years (reduced from ten by the Fourth Bureaucracy Relief Act, in force since 2025), and commercial letters for six years; § 147 of the Fiscal Code (Abgabenordnung) imposes parallel retention duties for tax purposes.
- [113] J. Camenisch and A. Lehmann, “(un) linkable pseudonyms for governmental databases,” in *Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security*, 2015, pp. 1467–1479.
- [114] J. Camenisch, S. Hohenberger, M. Kohlweiss, A. Lysyanskaya, and M. Meyerovich, “How to win the clonewars: efficient periodic n-times anonymous authentication,” in *Proceedings of the 13th ACM conference on Computer and communications security*, 2006, pp. 201–210.
- [115] M. Green, G. Kaptchuk, and G. Van Laer, “Abuse resistant law enforcement access systems,” in *Annual International Conference on the Theory and Applications of Cryptographic Techniques*. Springer, 2021, pp. 553–583.
- [116] S. Goldwasser and S. Park, “Public accountability vs. secret laws: can they coexist? a cryptographic proposal,” in *Proceedings of the 2017 on Workshop on Privacy in the Electronic Society*, 2017, pp. 99–110.
- [117] J. Frankle, S. Park, D. Shaar, S. Goldwasser, and D. Weitzner, “Practical accountability of secret processes,” in *27th USENIX Security Symposium (USENIX Security 18)*, 2018, pp. 657–674.
- [118] R. Mayrhofer, A. Lehmann, and a. shelat, “A brief note on cryptographic pseudonyms for anonymous credentials,” *arXiv preprint arXiv:2510.05419*, 2025.
- [119] M. Chase, F. B. Durak, and S. Vaudenay, “Anonymous tokens with hidden metadata bit from algebraic MACs,” *Cryptology ePrint Archive*, Paper 2022/1622, 2022. [Online]. Available: <https://eprint.iacr.org/2022/1622>
- [120] E. B. Sasson, A. Chiesa, C. Garman, M. Green, I. Miers, E. Tromer, and M. Virza, “Zerocash: Decentralized anonymous payments from bitcoin,” in *2014 IEEE symposium on security and privacy*. IEEE, 2014, pp. 459–474.
- [121] P. P. Tsang, M. H. Au, A. Kapadia, and S. W. Smith, “Blacklistable anonymous credentials: blocking misbehaving users without ttps,” in *Proceedings of the 14th ACM conference on Computer and communications security*, 2007, pp. 72–81.
- [122] “Truage,” <https://www.mytruage.org>, NACS, Conexus, 2026.
- [123] “Bundesgesetz über den elektronischen Identitätsnachweis und andere elektronische Nachweise (BGEID),” <https://www.fedlex.admin.ch/eli/fga/2025/20/>, Swiss Federal Chancellery, 2025.
- [124] European Parliament and Council of the European Union, “Regulation (EU) 2024/1183 establishing the European Digital Identity Framework,” <https://eur-lex.europa.eu/eli/reg/2024/1183/oj/eng>, 2024.
- [125] —, “Directive 2002/58/EC concerning the processing of personal data and the protection of privacy in the electronic communications sector (ePrivacy Directive),” <https://eur-lex.europa.eu/eli/dir/2002/58/oj>, 2002, art. 15(1) permits Member States to adopt legislative measures requiring retention of communications data where necessary, appropriate and proportionate for national security, defence, public security, or criminal investigation.

## APPENDIX A CHAT CONTROL

Chat control is a set of measures planned by the EU to detect CSAM (Child Sex and Abuse Material) in encrypted messages [21]. Proponents of chat control want to work around end-to-end encryption, e.g., using client-side scanning or detection orders for providers. Their goal is to search encrypted content and the proactive detection of suspicious behavior, e.g. CSAM. If suspicious patterns are found, alerts for further investigations are generated. Hence, *probable cause is created* from observing patterns in encrypted data. The politicians’ plans have provoked widespread resistance among researchers [22].

In contrast, our idea *does not create probable cause*, but acts on it. The CFT does not search for patterns in encrypted data or workaround end-to-end encryption. It simply revokes anonymity of single malicious users, following a controlled process respecting privacy of benign users.

The recurring push by EU politicians towards chat control demonstrates the necessity of a minimum level of accountability for privacy-preserving protocols. Some politicians would go as far as bypassing end-to-end encryption and surveil all citizens just to generate suspect lists. With the CFT, no encrypted data are mined for potential patterns. It simply balances the individual right to privacy with the societal right for self-protection in case of probable cause, respecting separation of powers in democratic countries.

## APPENDIX B

### ATTRIBUTE COMMITMENTS: MERKLE TREE VS. FLAT HASH

To prove that claim attributes are indeed part of a valid issuer-signed credential, two commitment representations can be used. In a **Merkle representation**, the issuer signs a Merkle root of all attributes and the prover shows membership proofs for only the used attributes. In a **flat-hash representation**, the issuer signs one flat hash over all attributes and the prover proves consistency of the used attributes with that signed hash. For this benchmark we use a zk-friendly implementation (Circom/rapidsnark, Poseidon hash).

This benchmark isolates only the attribute-to-commitment part: computing/proving consistency up to the Merkle root (Merkle case) or up to the flat hash (flat case). Signature verification is intentionally excluded, because it is the same cost in both variants and would not affect their relative comparison.

This benchmark was executed on a mobile-like aarch64 machine with 2 CPU cores and 4 GB of RAM. Each benchmark was repeated 10 times, and we report mean prover and verifier runtimes.

The table below compares both approaches for 8–64 total attributes and 1–16 used attributes.

TABLE V: Merkle vs. Flat Hash Performance (ms): Prover / Verifier. Fastest approach in bold.

| Used Attrs | Total Attrs    |                 |                 |                 |
|------------|----------------|-----------------|-----------------|-----------------|
|            | 8              | 16              | 32              | 64              |
| 1          | <b>66 / 16</b> | <b>76 / 18</b>  | <b>84 / 18</b>  | <b>92 / 16</b>  |
|            | 87 / 14        | 116 / 13        | 174 / 12        | 322 / 15        |
| 2          | 88 / 12        | <b>103 / 15</b> | <b>110 / 13</b> | <b>114 / 14</b> |
|            | <b>83 / 13</b> | 123 / 15        | 181 / 13        | 307 / 15        |
| 4          | 111 / 13       | 142 / 13        | <b>154 / 13</b> | <b>165 / 12</b> |
|            | <b>93 / 14</b> | <b>112 / 13</b> | 176 / 14        | 331 / 17        |
| 8          | 183 / 13       | 205 / 14        | 243 / 13        | <b>264 / 15</b> |
|            | <b>84 / 11</b> | <b>118 / 11</b> | <b>185 / 10</b> | 338 / 11        |
| 16         | —              | 366 / 11        | 408 / 11        | 445 / 10        |
|            | —              | <b>118 / 10</b> | <b>185 / 10</b> | <b>329 / 10</b> |

Note: Each cell shows Merkle on the first line and flat on the second line. Timings are rounded to the nearest millisecond and averaged over 10 iterations. Bold indicates the faster approach in that case.

Main takeaway: if  $n$  denotes the total number of attributes and  $k$  the number of attributes used in the proof, then the

Merkle-based approach has proving cost  $O(k \log n)$ , while the flat-hash approach has proving cost  $O(n)$ .

For small  $k$ , the logarithmic factor makes Merkle faster. As  $k$  grows, the gap shrinks and flat hashing becomes more competitive. Our implementation uses  $n = 32$  and  $k = 7$ , which is closest to the benchmark row  $n = 32$ ,  $k = 8$ . In that regime, the table already shows flat hashing performing better, which is why we adopted it.

## APPENDIX C

### CREDENTIAL NON-REVOCATION PROOF SCALING

We compose a packed status-list non-revocation check with the age-check+CFT presentation of §V-A. The issuer embeds a global revocation index in a signed attribute slot. Bits are packed at  $B = 253$  per Merkle leaf, a population of  $N$  credentials occupies  $L = \lceil N/B \rceil$  leaves, padded to the next power of two, so the authentication-path depth is  $d = \lceil \log_2 \lceil N/B \rceil \rceil$  (equivalently  $d = \ell - 7$  for  $N = 2^\ell$ ). The circuit proves a Merkle path of length  $d$  to a public root and that the indexed bit is unset (not revoked).

We time population sizes  $N \in \{2^{12}, 2^{16}, 2^{20}, 2^{24}\}$  on both stacks and both machine profiles (ten runs each). Figures 6 and 7 plot mean prover and verifier latency against  $\ell = \log_2 N$ , solid markers are measured, dashed segments extrapolate a depth- $d$  fit out to  $N = 2^{29}$  (EU-population upper bound,  $d = 22$ ). At  $d = 0$  the status-list path vanishes and intercepts should recover the CFT-only baseline of Table IV.

a) *Standard stack.*: Prove and verify grow roughly linearly in  $d$ :

$$\begin{aligned} T_{\text{prove}}^{\text{mobile}}(d) &\approx 197d + 2119, & T_{\text{verify}}^{\text{mobile}}(d) &\approx 156d + 1537, \\ T_{\text{prove}}^{\text{server}}(d) &\approx 115d + 1296, & T_{\text{verify}}^{\text{server}}(d) &\approx 88d + 898. \end{aligned}$$

Extrapolated to  $N = 2^{29}$  ( $d = 22$ ) this is about 6.5 s / 5.0 s on mobile and 3.8 s / 2.8 s on server environment.

b) *Zk-friendly stack.*: Prover time grows gently with  $d$ , verifier time is independent of  $N$  (fixed-size Groth16 proofs):

$$\begin{aligned} T_{\text{prove}}^{\text{mobile}}(d) &\approx 14.6d + 1197, & T_{\text{verify}}^{\text{mobile}} &\approx 34, \\ T_{\text{prove}}^{\text{server}}(d) &\approx 2.6d + 480, & T_{\text{verify}}^{\text{server}} &\approx 13. \end{aligned}$$

Extrapolated to  $N = 2^{29}$  proving is about 1.52 s on mobile and 0.54 s on server. Verification stays at about 34 ms (mobile) and 13 ms (server).

## APPENDIX D

### FULLY PRIVATE SEARCH BY ACTIVITY THRESHOLD

A. *Detailed Algorithms for Suspect-ID and Activity-Threshold Searches*

B. *Setting and Notation*

Let  $\mathbb{G}$  be the prime-order subgroup of BabyJubjub generated by the basepoint  $G = \text{Base8}$ , with scalar field  $\mathbb{Z}_q$  where  $q = \text{BABYJUB\_ORDER}$ . A holder secret key  $sk \in \mathbb{Z}_q$  has public key  $Q = sk \cdot G \in \mathbb{G}$ , and  $sk$  is additively-shared among  $n$  parties. ElGamal on  $\mathbb{G}$  encrypts a BabyJubjub point identifier  $ID \in \mathbb{G}$  as

$$\text{Enc}_Q(ID; r) = (c_1, c_3) = (r \cdot G, ID + r \cdot Q),$$

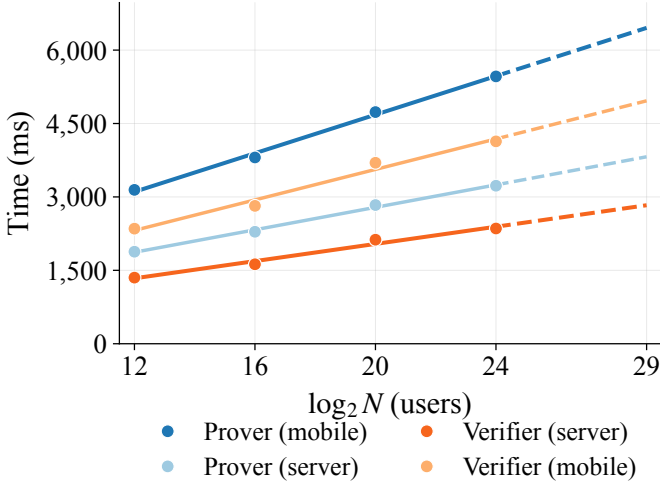


Fig. 6: Packed status-list non-revocation composed with age-check+CFT (standard stack): mean prover and verifier time versus population size  $N$  ( $\ell = \log_2 N$ ).

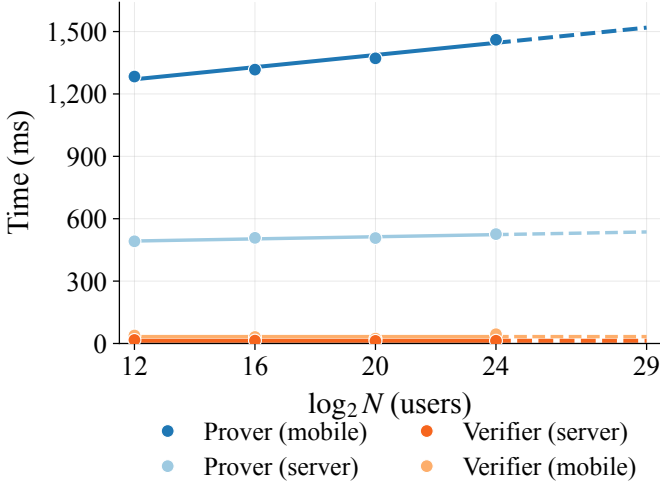


Fig. 7: Packed status-list non-revocation composed with age-check+CFT (zk-friendly stack): mean prover and verifier time versus population size  $N$  ( $\ell = \log_2 N$ ).

for  $ID \in \mathbb{G}$  and  $r \in \mathbb{Z}_q$ . We write  $ct = (c_1, c_3)$ . Decryption requires all the parties to each contribute a partial  $D_i = s_i \cdot c_1$ , which are then combined to obtain  $sk \cdot c_1$ , recovering  $ID = c_3 - sk \cdot c_1$  without ever reconstructing  $sk$ .

The corpus is a list  $C = (ct_1, \dots, ct_N)$  of ciphertexts encrypting unknown identities  $ID_1, \dots, ID_N$  under  $Q$ . For a threshold  $\tau$ , we want to reveal exactly those  $ID_i$  whose identity appears at least  $\tau$  times in  $C$ :

$$P_\tau(C, i) = \left[ |\{j : ID_j = ID_i\}| \geq \tau \right].$$

The protocol has two phases: a pairwise *Plaintext Equality Test* (PET) phase that yields a blinded equality witness for every pair, and an MPC phase that consumes those witnesses to compute and reveal the per-row predicate bits  $P_\tau(C, i)$ . Rows whose bit is 1 are then opened.

### C. The Plaintext Equality Test

The PET, due to Jakobsson and Juels [94], is the workhorse primitive. Given  $ct_a = (c_{1,a}, c_{3,a})$  and  $ct_b = (c_{1,b}, c_{3,b})$  encrypting  $ID_a, ID_b$  under the same key  $Q$ , define the homomorphic difference

$$\Delta(ct_a, ct_b) := (c_{1,a} - c_{1,b}, c_{3,a} - c_{3,b}),$$

which, by linearity, is an encryption of  $ID_a - ID_b$ . Each of the  $t$  cooperating parties samples a fresh  $\alpha_i \in \mathbb{Z}_q$  uniformly at random and contributes  $\alpha_i \cdot \Delta$ . The summed contribution gives the *blinded difference*

$$\Delta'(ct_a, ct_b) := (\alpha \cdot (c_{1,a} - c_{1,b}), \alpha \cdot (c_{3,a} - c_{3,b})),$$

where  $\alpha = \sum_i \alpha_i \bmod q$ ; this is an encryption of  $\alpha(ID_a - ID_b)$ .

Were the parties to threshold-decrypt  $\Delta'$  here, they would recover the joint point  $M' = \alpha(ID_a - ID_b) \in \mathbb{G}$  in the clear, and the bit  $[M' = O]$  would tell them whether the two IDs are equal — exposing the entire pairwise matching pattern of the corpus across all PETs. To prevent this leakage, our protocol does *not* reconstruct  $M'$ . Instead, each party  $i$  computes its own partial decryption solely. The joint point  $M'$  then lives only inside the MPC, in shared form, and is never opened. The cooperating parties therefore learn nothing about whether  $ID_a = ID_b$  from the PET itself.

**Lemma 3** (PET output distribution). *Inside the MPC, the (still-shared) joint point recovered from the  $D_i$  and  $\Delta'.c_3$  equals  $M' = \alpha(ID_a - ID_b)$ . If  $ID_a = ID_b$ , then  $M' = O$  (the identity element of  $\mathbb{G}$ ) with probability 1. If  $ID_a \neq ID_b$  and at least one honest party contributed a uniform  $\alpha_i$ , then  $M'$  is uniformly distributed over  $\mathbb{G} \setminus \{O\}$ .*

*Proof sketch.*  $M' = \alpha(ID_a - ID_b)$ . When  $ID_a = ID_b$  this is  $O$  for any  $\alpha$ . Otherwise  $ID_a - ID_b$  generates  $\mathbb{G}$  (since  $\mathbb{G}$  has prime order), the map  $\alpha \mapsto \alpha(ID_a - ID_b)$  is a bijection  $\mathbb{Z}_q \rightarrow \mathbb{G}$ , and a single honest  $\alpha_i$  suffices to make  $\alpha$  uniform; the probability of hitting  $O$  is  $1/q$  and is treated as negligible.  $\square$

### D. Computing the Predicate inside MPC

Running a PET on every unordered pair  $(i, j)$  with  $i < j$  yields, for each pair,  $t$  partial decryptions  $D_{ij,1}, \dots, D_{ij,t} \in \mathbb{G}$  (one from each cooperating party) plus the public ciphertext component  $\Delta'_{ij}.c_3$ . The MPC takes the partials as secret-shared inputs and performs the remaining work: reconstruct  $M'_{ij}$  in shared form, test it against  $O$ , aggregate the equality matrix, and reveal only the per-CFT predicate bits.

We use a OT-based dishonest majority protocol (MP-SPDZ's `mascot-party.x`). The MPC program executed by the parties is:

**Step 1. Secret-share the partials.** For each pair  $(i, j)$ , each cooperating party  $\ell$  feeds its additive share  $D_{ij,\ell}$  into the MPC. The ciphertext component  $\Delta'_{ij}.c_3$  is provided as a public constant.

**Step 2. Reconstruct the joint point as shares.** Inside the MPC, sum the  $t$  shared partials and subtract from

$\Delta'_{ij} \cdot c_3$  to obtain a shared representation of  $M'_{ij}$ . This is  $t - 1$  twisted-Edwards point additions per pair, performed on secret-shared coordinates.

**Step 3. Per-pair zero test.** For each pair, the MPC computes a shared bit  $\tilde{b}_{ij} = [M'_{ij} = O]$ . This bit is never opened; it lives only as a Shamir share.

**Step 4. Build the matrix and sum rows.** Place the  $\tilde{b}_{ij}$  into a shared symmetric  $N \times N$  matrix  $\tilde{B}$  with  $\tilde{b}_{ii} = 1$  for the self-match. Compute per-row sums  $\text{count}_i = \sum_j \tilde{b}_{ij}$ . Summation is free in Shamir.

**Step 5. Threshold comparison.** For each  $i$ , evaluate the shared predicate  $\tilde{P}_i = [\text{count}_i \geq \tau]$  using the standard MPC comparison subprotocol.

**Step 6. Reveal predicate bits.** Open exactly the  $N$  bits  $\tilde{P}_1, \dots, \tilde{P}_N$ . Nothing else from inside the MPC is revealed: not  $M'_{ij}$ , not the equality matrix  $\tilde{B}$ , not the row counts  $\text{count}_i$ , and not which specific pairs caused  $\tilde{P}_i = 1$ .

#### E. Conditional Opening

Once the parties hold the public bit vector  $P_1, \dots, P_N$ , they threshold-decrypt  $ct_i$  exactly for each  $i$  with  $P_i = 1$ , recovering  $ID_i$ . Duplicates among the revealed identities are deduplicated client-side (the same  $ID$  may have  $P_i = 1$  for several  $i$ ). Records with  $P_i = 0$  remain encrypted.

#### F. Implementation

Implementing Step 2 of Appendix D-D on MP-SPDZ [108] is non-trivial: MP-SPDZ exposes secret-shared field arithmetic over its own native prime field, not over BabyJubjub. Realising a twisted-Edwards point addition over shared inputs therefore requires encoding the curve formula as a circuit of MP-SPDZ multiplications and additions (the projective `add-2008-bbjlp` formula uses ten multiplications per addition), and re-encoding shares into BabyJubjub's coordinate field at every input/output boundary.

For the prototype we evaluate in this paper, we factor the protocol along the curve/MPC boundary and run each side in its native field. Concretely: the cooperating parties broadcast their PET partials and combine them into  $M'_{ij}$  *outside* MPC — in our JavaScript coordinator process, where BabyJubjub arithmetic is cheap — and feed only the coordinates of  $M'_{ij}$  to the MPC, which then runs Steps 3–6 unchanged. We refer to this variant as *twisted-Edwards on-disk*<sup>4</sup>. Under this variant, the cooperating parties learn the per-pair equality bits during the PET phase — a leakage that does *not* occur in the ideal protocol above. The variant therefore measures the cost of every other step accurately but does not implement the full privacy guarantee.

<sup>4</sup>“On-disk” is a slight misnomer: the curve sums happen in the coordinator process, not in storage. We use the term to emphasise that the points cross the MPC boundary in plaintext.

## APPENDIX E PRIVACY AND SECURITY OF THE CRYPTOGRAPHIC FORENSIC TRAIL (CFT)

We prove the statements of Theorems 1 and 2 from §IV-C. Throughout, let  $E$  be an elliptic curve over  $\mathbb{F}_p$ , let  $G \in E(\mathbb{F}_p)$  be a generator of a cyclic subgroup of prime order  $q$ , and model the hash function used in the construction as a random oracle  $H$ . The user holds a key pair  $(ID_u, sk_u)$  with  $ID_u = sk_u G$ ; the secret key  $sk_u$  is hardware-bound (WSCD) and never leaves the device. We write  $PK := sk \cdot G$  for the joint revocation public key ( $sk = sk_P + sk_J + sk_N$  in the distributed setting), and write  $m := H(t, r_2 PK)$  for the binding message signed in  $C_4$ .

**Background.** We now present some background to better understand the following proofs:

- **The DDH Assumption:** the decisional Diffie-Hellman problem is hard in  $\langle G \rangle$ .
- **The Random Oracle Model:** The hash function is modeled as a random oracle  $H: \{0, 1\}^* \rightarrow \{0, 1\}^\ell$ , accessible to all parties including the adversary.
- **EUFCMA:** the signature scheme (Sign, Verify) used for  $C_4$  is existentially unforgeable under chosen-message attack.

#### A. IND-Style Indistinguishability

The adversary chooses two candidate key pairs  $(ID_0, sk_0)$  and  $(ID_1, sk_1)$ —including the secret keys—and is given a challenge CFT that encrypts one of them, while also having access to a sampling oracle that returns fresh valid CFTs for the *same* hidden key pair, with fresh randomness each time. The adversary may query this oracle an arbitrary number of times, as long as the total number of queries is bounded by some polynomial  $q(\lambda)$  in the security parameter.

Giving  $\mathcal{A}$  both secret keys does not break the game: to check  $C_4$  under either key,  $\mathcal{A}$  needs the binding message  $m = H(t, r_2 PK)$ , and computing  $r_2 PK$  from the public values  $(C_2, PK) = (r_2 G, sk G)$  is equivalent to CDH. Thus  $\mathcal{A}$  cannot run Verify offline.

- 1) Sample  $sk \xleftarrow{\$} \mathbb{Z}_q \setminus \{0, 1\}$ . Set  $PK := sk G$ .
- 2) The adversary outputs two candidate key pairs  $(ID_0, sk_0)$ ,  $(ID_1, sk_1)$  with  $ID_i = sk_i G$ , and a tag  $t^* \in \mathbb{Z}_q \setminus \{0\}$ . Sample a challenge bit  $b \xleftarrow{\$} \{0, 1\}$  and a challenge triple  $(r_1^*, r_2^*) \xleftarrow{\$} (\mathbb{Z}_q \setminus \{0, 1\})^2$ . Set

$$(C_1^*, C_2^*, C_3^*, C_4^*) := (r_1^* G, r_2^* G, ID_b + r_1^* PK, \text{Sign}(sk_b, H(t^*, r_2^* PK))).$$

Give  $\mathcal{A}$  the public parameters  $(G, PK)$  and the challenge transcript  $(C_1^*, C_2^*, C_3^*, C_4^*, t^*)$ .

- 3) Oracle Samp: on each query, sample fresh

$$(r_1, r_2, t) \xleftarrow{\$} (\mathbb{Z}_q \setminus \{0, 1\})^2 \times (\mathbb{Z}_q \setminus \{0\})$$

and return

$$(C_1, C_2, C_3, C_4, t) := (r_1 G, r_2 G, ID_b + r_1 PK, \text{Sign}(sk_b, H(t, r_2 PK)), t).$$

4) The adversary outputs a bit  $b'$  and wins if  $b' = b$ .

If an adversary  $\mathcal{A}$  wins this game with probability  $\frac{1}{2} + \varepsilon$  while making at most  $q_\lambda$  queries to Samp and H, then there exists a PPT algorithm  $\mathcal{B}$  solving DDH with advantage  $\text{Adv}^{DDH}(\mathcal{B}) \geq \varepsilon - q_\lambda/q$ , which yields Theorem 1.

a) *Proof of Theorem 1:* We construct an explicit PPT algorithm  $\mathcal{B}$  that uses  $\mathcal{A}$  as a subroutine to distinguish DDH tuples.

**Input to  $\mathcal{B}$ .**  $\mathcal{B}$  receives a DDH challenge  $(G, aG, bG, Z)$  where either  $Z = abG$  (real case) or  $Z \xleftarrow{\$} \langle G \rangle$  (random case), and must output a bit.

**Simulation by  $\mathcal{B}$ .**  $\mathcal{B}$  simulates the indistinguishability game for  $\mathcal{A}$  as follows:

- 1) Set the public key  $PK := bG$  (so the implicit secret key is  $sk = b$ , unknown to  $\mathcal{B}$ ).
- 2) Receive  $(ID_0, sk_0)$ ,  $(ID_1, sk_1)$  and  $t^*$  from  $\mathcal{A}$  (abort if  $ID_i \neq sk_i G$ ). Sample a challenge bit  $\beta \xleftarrow{\$} \{0, 1\}$  and let  $(ID_\beta, sk_\beta)$  denote the hidden key pair. Sample  $r_2^* \xleftarrow{\$} \mathbb{Z}_q \setminus \{0, 1\}$  and set

$$C_1^* := aG, C_2^* := r_2^* G, C_3^* := ID_\beta + Z.$$

(Implicitly, define  $r_1^* := a$  so that  $C_1^* = r_1^* G$ .) Since  $\mathcal{B}$  knows the scalar  $r_2^*$  and the point  $PK$ , it can compute  $r_2^* PK$  by scalar multiplication, query  $m^* \leftarrow H(t^*, r_2^* PK)$ , and set

$$C_4^* := \text{Sign}(sk_\beta, m^*).$$

Answer all other H-queries uniformly at random, consistently.

- 3) Send  $\mathcal{A}$  the challenge transcript  $(C_1^*, C_2^*, C_3^*, C_4^*, t^*)$  along with the public parameters  $(G, PK)$ .
- 4) Answer each Samp query from  $\mathcal{A}$  by sampling fresh:

$$(r_i, r_{2,i}, t_i) \xleftarrow{\$} (\mathbb{Z}_q \setminus \{0, 1\})^2 \times (\mathbb{Z}_q \setminus \{0\})$$

Define  $r_{1,i} := r_1^* + r_i$  and set

$$C_1 := C_1^* + r_i G, C_2 := r_{2,i} G, C_3 := C_3^* + r_i PK.$$

(If  $Z = abG$  then  $C_3^* = ID_\beta + r_1^* PK$ , hence  $C_3 = ID_\beta + r_{1,i} PK$  and  $C_1 = r_{1,i} G$ .)

Compute  $m_i \leftarrow H(t_i, r_{2,i} PK)$  and  $C_4 := \text{Sign}(sk_\beta, m_i)$ . Return  $(C_1, C_2, C_3, C_4, t_i)$ .

$\mathcal{B}$  outputs 1 iff  $\mathcal{A}$  outputs the correct bit  $\beta$ , otherwise  $\mathcal{B}$  outputs 0.

**Case 1:  $Z = abG$  (real case).**

Then  $C_1^* = aG$  and

$$C_3^* = ID_\beta + Z = ID_\beta + abG = ID_\beta + a \cdot PK = ID_\beta + r_1^* PK.$$

Moreover, for each Samp reply we pick fresh  $r_i \xleftarrow{\$} \mathbb{Z}_q$  and define  $r_{1,i} := r_1^* + r_i$ ; then  $C_1 = C_1^* + r_i G = r_{1,i} G$  and  $C_3 = C_3^* + r_i PK = ID_\beta + r_{1,i} PK$ . The signatures  $C_4$  are honest signatures under  $sk_\beta$  on the correct binding messages. Therefore the simulated transcript (and likewise each Samp

reply) is *identically distributed* to a real game transcript. Therefore:

$$\Pr[\mathcal{A} \text{ wins} \mid Z = abG] = \frac{1}{2} + \varepsilon.$$

This means that when  $Z = abG$ ,  $\mathcal{B}$  outputs 1 with probability

$$\Pr[\mathcal{B} = 1 \mid Z = abG] = \frac{1}{2} + \varepsilon.$$

**Case 2:  $Z \xleftarrow{\$} \langle G \rangle$  (random case).**

$Z$  is a uniformly random point in  $\langle G \rangle$ , independent of  $ID_\beta, PK, C_1^*$  and  $C_2^*$ . Consequently, the  $C_3$  components are distributed as  $ID_\beta + (Z + r_i PK)$  for fresh  $r_i \xleftarrow{\$} \mathbb{Z}_q$ . Since  $r_i PK$  is uniform over  $\langle G \rangle$ , every  $C_3$  is uniform over  $\langle G \rangle$  and independent of  $ID_\beta$ , thus even polynomially many sampling queries leak no information about  $ID_\beta$  through  $C_3$ .

It remains to argue that  $C_4$  does not help either, even though  $\mathcal{A}$  knows both  $sk_0$  and  $sk_1$ . To test whether  $C_4$  verifies under  $ID_0$  or  $ID_1$ ,  $\mathcal{A}$  must evaluate  $\text{Verify}(ID_i, C_4, m)$  for  $m = H(t, r_2 PK)$ . By the random oracle assumption,  $\mathcal{A}$  obtains this  $m$  only by querying H at the exact point  $(t, r_2 PK)$ . Computing  $r_2 PK$  from the public pair  $(C_2, PK) = (r_2 G, skG)$  is CDH-hard; equivalently, the probability that any of  $\mathcal{A}$ 's  $q_\lambda$  random-oracle queries coincidentally hits the correct point is at most  $q_\lambda/q$ . Without  $m$ ,  $\mathcal{A}$  cannot run verification under either key, so  $C_4$  yields no distinguishing advantage beyond this negligible loss. Therefore the challenge bit remains hidden except with this negligible loss, and we get

$$\Pr[\mathcal{B} = 1 \mid Z \text{ random}] \leq \frac{1}{2} + \frac{q_\lambda}{q}.$$

**Distinguishing Advantage.**  $\mathcal{B}$ 's DDH advantage is:

$$\begin{aligned} \text{Adv}^{DDH}(\mathcal{B}) &= \left| \Pr[\mathcal{B} = 1 \mid Z = abG] \right. \\ &\quad \left. - \Pr[\mathcal{B} = 1 \mid Z \text{ random}] \right| \\ &\geq \varepsilon - \frac{q_\lambda}{q}. \end{aligned}$$

If  $\varepsilon$  is non-negligible, so is  $\mathcal{B}$ 's advantage, contradicting the DDH assumption.

## B. Unforgeability

We now prove that the CFT is also unforgeable, that is, a CFT cannot be repurposed to a fresh request tag  $t'$ . Throughout this subsection we assume that the adversary  $\mathcal{A}$  *does not know* the user's hardware-held signing key  $sk_u$  but may know the corresponding public key  $ID_u = sk_u G$ , the joint public key  $PK$ , and previously issued CFT transcripts.

A purported forgery for a new tag  $t'$  is a tuple  $(C'_1, C'_2, C'_3, C'_4, t')$  that opens correctly under  $ID_u$ :

$$C'_3 = ID_u + sk C'_1 \text{ and } \text{Verify}(ID_u, C'_4, H(t', sk C'_2)) = 1.$$

Knowing  $ID_u$ ,  $\mathcal{A}$  can freely sample  $r'_1, r'_2$  and set  $C'_1 = r'_1 G$ ,  $C'_2 = r'_2 G$ ,  $C'_3 = ID_u + r'_1 PK$ , so forging consistent



$(C'_1, C'_2, C'_3)$  is easy. The binding check, however, requires a valid signature

$$C'_4 = \text{Sign}(sk_u, H(t', r'_2 PK)).$$

Under EUF-CMA, no PPT adversary that does not hold  $sk_u$  can produce such a  $C'_4$  on a fresh message  $H(t', r'_2 PK)$ . Therefore forging a complete valid CFT for a new tag is infeasible, which yields Theorem 2.

---

**Algorithm 3: CFTRevokeBySuspectID**


---

**Parties:** Police  $P$ , Judge  $J$ , NGO  $N$ , verifiers  $V$ .

**Inputs:**  $\text{reason}$ ,  $\text{aux}$ ,  $ID_{SW}$ ,  $\text{filter}$ ,  $ID_{\text{suspect}}$ , public keys  $pk_i$  for  $i \in \{P, J, N\}$ ; each party  $i$  holds its own secret key  $sk_i$ .

**Convention:**  $\#(x, Y)$  counts occurrences of  $x$  in multiset  $Y$ .

```

1:  $\sigma_{SW} \leftarrow \text{IssueCondWarrant}(P, J, \text{reason}, \text{aux},$ 
    $ID_{SW}, \text{filter}, ID_{\text{suspect}})$ 
2:  $\mathcal{C}_V \leftarrow \text{ObtainTrails}(P, \{V\}, \sigma_{SW}, \text{filter})$ 
3:  $P$  prepends  $ID_{\text{suspect}}$  to each entry in  $\mathcal{C}_V$ .
4:  $\mathcal{C}_P \leftarrow \text{BatchLink}(P, \mathcal{C}_V, \text{filter}, sk_P)$ 

5:  $P$  sends  $\mathcal{C}_P, \sigma_{SW}$  to  $J$ .
6: if  $\sigma_{SW}$  invalid then
7:    $J$  aborts.
8:  $\mathcal{C}_J \leftarrow \text{BatchLink}(J, \mathcal{C}_P, \text{filter}, sk_J)$ 
9:  $\sigma_{SW,J} \leftarrow \text{Sign}_{sk_J}(ID_{SW} \parallel H(\mathcal{C}_J))$ 
10:  $J$  sends  $\mathcal{C}_J, \sigma_{SW,J}$  to  $P$ .

11:  $P$  sends  $\mathcal{C}_J, \sigma_{SW}, \sigma_{SW,J}$  to  $N$ .
12: if  $\sigma_{SW}$  or  $\sigma_{SW,J}$  invalid then
13:    $N$  aborts.
14:  $\mathcal{C}_N \leftarrow \text{BatchLink}(N, \mathcal{C}_J, \text{filter}, sk_N)$ 
   (entries carry  $PID = D_{(3,N)}$ )
15:  $\mathcal{C}_{N,2} \leftarrow \text{BatchDeanonimize}(N, \{\text{entries in } \mathcal{C}_N \text{ with } PID =$ 
    $PID_{\text{suspect}}\}, sk_N)$ 
16:  $\sigma_{SW,N} \leftarrow \text{Sign}_{sk_N}(ID_{SW} \parallel H(\mathcal{C}_{N,2}))$ 
17:  $N$  sends  $\mathcal{C}_{N,2}, \sigma_{SW}, \sigma_{SW,N}$  to  $P$ .

18:  $P$  forwards  $\mathcal{C}_{N,2}, PID_{\text{suspect},N}, \sigma_{SW}, \sigma_{SW,N}$  to  $J$ .
19: if  $\sigma_{SW}$  or  $\sigma_{SW,N}$  invalid then
20:    $J$  aborts.
21:  $\mathcal{C}_{J,2} \leftarrow \text{BatchDeanonimize}(J, \{\text{entries in } \mathcal{C}_{N,2} \text{ with } PID =$ 
    $PID_{\text{suspect}}\}, sk_J)$ 
22:  $P$  receives  $\mathcal{C}_{J,2}, PID_{\text{suspect},J}$  from  $J$ .

23:  $\mathcal{C}_{P,2} \leftarrow \text{BatchDeanonimize}(P, \{\text{entries in } \mathcal{C}_{J,2} \text{ with } PID =$ 
    $PID_{\text{suspect}}\}, sk_P)$ 
24:  $P$  combines partial decryptions and checks bindings:
25: for all entries in  $\mathcal{C}_{P,2}$  do
    $D_2 \leftarrow D_{(2,P)} + D_{(2,N)} + D_{(2,J)}$ 
    $t \leftarrow H(ts, RID, ID_V)$ 
26:   if  $\text{VerifySign}_{ID_{\text{suspect}}}(C_4, H(t, D_2)) = 0$  then
27:     discard entry from  $\mathcal{C}_{P,2}$ .
28:  $P$  outputs  $ID_{\text{suspect}}$  and the set of opened traces  $\mathcal{C}_{P,2}$ 

```

---

$\text{IssueCondWarrant}(P, J, \text{reason}, \text{aux}, ID_{SW},$   
 $\text{filter}, ID_{\text{suspect}})$

---

```

1:  $P$  presents  $(\text{reason}, ID_{\text{suspect}}, \text{filter})$  to  $J$ .
2: if  $\text{reason}, ID_{\text{suspect}}$ , or  $\text{filter}$  not legitimate then
3:    $J$  aborts.
4:  $\sigma_{SW} \leftarrow \text{Sign}_{sk_J}(ID_{SW} \parallel \text{reason} \parallel \text{aux} \parallel$ 
    $\text{filter} \parallel ID_{\text{suspect}})$ 
5: return  $\sigma_{SW}$ 

```

---

$\text{ObtainTrails}(P, \{V\}, \sigma_{SW}, \text{filter})$

---

```

1:  $\mathcal{C}_V \leftarrow \emptyset$ 
2: for all verifiers  $V$  in scope do
3:    $P$  sends  $\sigma_{SW}$  to  $V$ .
4:   if  $\sigma_{SW}$  invalid then
5:      $V$  aborts.
6:   for all  $(CFT, ts, RID, ID_V)$  satisfying  $\text{filter}$  do
7:      $\sigma_{SW,V} \leftarrow \text{Sign}_{sk_V}(ID_{SW} \parallel ts \parallel RID \parallel$ 
        $ID_V \parallel H(CFT))$ 
8:      $D_{(1,V)} \leftarrow C_1$ 
9:      $D_{(3,V)} \leftarrow C_3$ 
10:    add  $(CFT, (ts, RID, ID_V),$ 
        $D_{(1,V)}, D_{(3,V)}, \sigma_{SW,V})$  to  $\mathcal{C}_V$ .
11: return  $\mathcal{C}_V$ 

```

---

$\text{BatchLink}(X, \mathcal{C}_{\text{in}}, \text{filter}, sk_X)$

---

```

1:  $\mathcal{C}_{\text{out}} \leftarrow \emptyset$ .
2: for all  $e$  in  $\mathcal{C}_{\text{in}}$  with valid  $\sigma_{SW,V}$  satisfying  $\text{filter}$  do
3:   generate fresh  $k_X$ ;
4:   Parse  $e$  as:  $(PID_{(\text{suspect}, \text{prev})}, CFT,$ 
        $(ts, RID, ID_V), D_{(1, \text{prev})}, D_{(3, \text{prev})}, \sigma_{SW,V})$ 
5:    $(D_{(1,X)}) \leftarrow k_X \cdot D_{(1, \text{prev})}$ 
6:    $(D_{(3,X)}) \leftarrow k_X \cdot (D_{(3, \text{prev})} - sk_X \cdot D_{(1, \text{prev})})$ 
7:    $PID_{(\text{suspect}, X)} \leftarrow k_X \cdot PID_{(\text{suspect}, \text{prev})}$ 
8:   add the following tuple to  $\mathcal{C}_{\text{out}}$ :
        $(PID_{(\text{suspect}, X)}, CFT, (ts, RID, ID_V),$ 
        $D_{(1,X)}, D_{(3,X)}, \sigma_{SW,V})$ 
9: return  $\mathcal{C}_{\text{out}}$ 

```

---

$\text{BatchDeanonimize}(X, \mathcal{C}_{\text{in}}, sk_X)$

---

```

1:  $\mathcal{C}_{\text{out}} \leftarrow \emptyset$ .
2: for all  $e$  in  $\mathcal{C}_{\text{in}}$  with valid  $\sigma_{SW,V}$  satisfying  $\text{filter}$  do
3:   get  $CFT = (C_1, C_2, C_3, C_4)$  from  $e$ 
4:    $D_{(2,X)} \leftarrow sk_X \cdot C_2$ 
5:   append  $D_{(2,X)}$  to the entry  $e$ 
6:   add  $e$  to  $\mathcal{C}_{\text{out}}$ .
7: return  $\mathcal{C}_{\text{out}}$ 

```

Fig. 8: Searching by suspect ID: CFTRevokeBySuspectID (left) and its subroutines (right).

$\text{CFTCondOpen}(P, J, N, \{V\}, \text{reason}, \text{aux}, ID_{SW}, \text{filter}, \tau)$

**Parties:** Police  $P$ , Judge  $J$ , NGO  $N$ , verifiers  $V$ .

**Inputs:**  $\text{reason}$ ,  $\text{aux}$ ,  $ID_{SW}$ ,  $\text{filter}$ ,  $\tau$ , key pairs  $(pk_i, sk_i)$  and warrant-scoped symmetric keys  $k_i$  for  $i \in \{P, J, N\}$  (fresh per warrant instance).

**Convention:**  $\#(x, Y)$  counts occurrences of  $x$  in multiset  $Y$ .

```

1:  $\sigma_{SW} \leftarrow \text{IssueCondWarrant}(P, J, \text{reason}, \text{aux}, ID_{SW}, \text{filter}, \tau)$ 
2:  $\{CFT\}_V \leftarrow \text{ObtainTrails}(P, \{V\}, \sigma_{SW}, \text{filter})$ 
3:  $\{CFT\}_P, k_P \leftarrow \text{BatchLink}(P, \{CFT\}_V, \text{filter}, sk_P)$ 

4:  $P$  sends  $\{CFT\}_P, \sigma_{SW}$  to  $J$ .
5: if  $\sigma_{SW}$  invalid then
6:    $J$  aborts.
7:  $\{CFT\}_J, k_J \leftarrow \text{BatchLink}(J, \{CFT\}_P, \text{filter}, sk_J)$ 
8:  $\sigma_{SW, J} \leftarrow \text{Sign}_{sk_J}(ID_{SW} \parallel H(\{CFT\}_J))$ 
9:  $J$  sends  $\{CFT\}_J, \sigma_{SW, J}$  to  $P$ .

10:  $P$  sends  $\{CFT\}_J, \sigma_{SW}, \sigma_{SW, J}$  to  $N$ .
11: if  $\sigma_{SW}$  or  $\sigma_{SW, J}$  invalid then
12:    $N$  aborts.
13:  $\{CFT\}_N, k_N \leftarrow \text{BatchLink}(N, \{CFT\}_J, \text{filter}, sk_N)$ 
   (entries carry  $\text{PID} = D_{(3, N)}$ )
14:  $\{\text{PID}\}_{\text{suspect}} = \{\text{PID} : \text{PID} \in \{CFT\}_N \text{ s.t. } \#(\text{PID}, \{CFT\}_N) > \tau$ 
15: if  $\{\text{PID}\}_{\text{suspect}}$  is empty then
16:    $N$  aborts.
17:  $\{CFT\}_{N, 2} \leftarrow \text{BatchDeanonimize}(N,$ 
    $\{\text{entries in } \{CFT\}_N \text{ with } \text{PID} \in \{\text{PID}\}_{\text{suspect}}\}, sk_N, k_N)$ 
18:  $\sigma_{SW, N} \leftarrow \text{Sign}_{sk_N}(ID_{SW} \parallel H(\{CFT\}_{N, 2}))$ 
19:  $N$  sends  $\{CFT\}_{N, 2}, \sigma_{SW}, \sigma_{SW, N}$  to  $P$ .

20:  $P$  forwards  $\{CFT\}_{N, 2}, \sigma_{SW}, \sigma_{SW, N}$  to  $J$ .
21: if  $\sigma_{SW}$  or  $\sigma_{SW, N}$  invalid then
22:    $J$  aborts.
23:  $\{\text{PID}\}_{\text{suspect}, N} = \{\text{PID} : \text{PID} \in$ 
    $\{CFT\}_{N, 2} \text{ s.t. } \#(\text{PID}, \{CFT\}_{N, 2}) > \tau$ 
24:  $\{CFT\}_{J, 2} \leftarrow \text{BatchDeanonimize}(J,$ 
    $\{\text{entries in } \{CFT\}_{N, 2} \text{ with } \text{PID} \in \{\text{PID}\}_{\text{suspect}, N}\}, sk_J, k_J)$ 
25:  $P$  receives  $\{CFT\}_{J, 2}, \{\text{PID}\}_{\text{suspect}, J}$  from  $J$ .

26:  $\{\text{PID}\}_{\text{suspect}, J} = \{\text{PID} : \text{PID} \in$ 
    $\{CFT\}_{J, 2} \text{ s.t. } \#(\text{PID}, \{CFT\}_{J, 2}) > \tau$ 
27:  $\{CFT\}_{P, 2} \leftarrow \text{BatchDeanonimize}(P,$ 
    $\{\text{entries in } \{CFT\}_{J, 2} \text{ with } \text{PID} \in \{\text{PID}\}_{\text{suspect}, J}\}, sk_P, k_P)$ 
   (entries carry  $ID_U = \text{PID}_P$ )
28:  $P$  combines partial decryptions and checks bindings:
29: for all entries in  $\{CFT\}_{P, 2}$  do
    $D_2 \leftarrow D_{(2, P)} + D_{(2, N)} + D_{(2, J)}$ 
    $t \leftarrow H(ts, \text{RID}, ID_V)$ 
30:   if  $\text{VerifySign}_{ID_U}(C_4, H(t, D_2)) = 0$  then
31:     discard entry from  $\{CFT\}_{P, 2}$ .
32:  $\{ID_U\}_{\text{suspect}} = \{ID_U : ID_U \in$ 
    $\{CFT\}_{P, 2} \text{ s.t. } \#(ID_U, \{CFT\}_{P, 2}) > \tau$ 
33:  $\{CFT\}_{\text{suspect}} = \{\text{entries in } \{CFT\}_{P, 2} \text{ with } ID_U \in \{ID_U\}_{\text{suspect}}\}$ 
34:  $P$  outputs  $\{ID_U\}_{\text{suspect}}$  and the set of opened traces  $\{CFT\}_{\text{suspect}}$ 

```

$\text{IssueCondWarrant}(P, J, \text{reason}, \text{aux}, ID_{SW}, \text{filter}, \tau)$

```

1:  $P$  presents  $(\text{reason}, \tau, \text{filter})$  to  $J$ .
2: if  $\text{reason}$ ,  $\tau$ , or  $\text{filter}$  not legitimate then
3:    $J$  aborts.
4:  $\sigma_{SW} \leftarrow \text{Sign}_{sk_J}(ID_{SW} \parallel \text{reason} \parallel \text{aux} \parallel \text{filter} \parallel \tau)$ 
5: return  $\sigma_{SW}$ 

```

$\text{BatchLink}(X, \{CFT\}_{\text{in}}, \text{filter}, sk_X)$

```

1: generate fresh  $k_X$ ;  $\{CFT\}_{\text{out}} \leftarrow \emptyset$ .
2: for all  $e$  in  $\{CFT\}_{\text{in}}$  with valid  $\sigma_{SW, V}$  satisfying
   filter do
3:   Parse  $e$  as:  $(CFT, (ts, \text{RID}, ID_V),$ 
      $D_{(1, \text{prev})}, D_{(3, \text{prev})}, \sigma_{SW, V})$ 
4:    $(D_{(1, X)}) \leftarrow k_X \cdot D_{(1, \text{prev})}$ 
5:    $(D_{(3, X)}) \leftarrow k_X \cdot (D_{(3, \text{prev})} - sk_X \cdot D_{(1, \text{prev})})$ 
6:   add  $(CFT, (ts, \text{RID}, ID_V),$ 
      $D_{(1, X)}, D_{(3, X)}, \sigma_{SW, V})$  to  $\{CFT\}_{\text{out}}$ .
7: return  $\{CFT\}_{\text{out}}, k_X$ 

```

$\text{BatchDeanonimize}(X, \{CFT\}_{\text{in}}, sk_X, k_X)$

```

1:  $\{CFT\}_{\text{out}} \leftarrow \emptyset$ .
2: for all  $e$  in  $\{CFT\}_{\text{in}}$  with valid  $\sigma_{SW, V}$  satisfying
   filter do
3:   get  $\text{PID}_{\text{prev}}$  from  $e$ 
4:    $\text{PID}_X = k_X^{-1} \cdot \text{PID}_{\text{prev}}$ 
5:   replace  $\text{PID}_{\text{prev}}$  with  $\text{PID}_X$  in  $e$ 
6:    $D_{(2, X)} \leftarrow sk_X \cdot C_2$ 
7:   append  $D_{(2, X)}$  to the entry  $e$ 
8:   add  $e$  to  $\{CFT\}_{\text{out}}$ .
9: return  $\{CFT\}_{\text{out}}$ 

```

Fig. 9: Searching by activity threshold (without MPC): conditional CFT opening  $\text{CFTCondOpen}$  (left) and its subroutines (right).